PDF Digital Signatures — A Technical Reference

PDFalyzer Studio Contributors

2026-03-06

Contents

0.1 Preface . . . 1
0.1.1 Who This Book Is For . . . 1
0.1.2 What This Book Is Not . . . 1
0.1.3 How This Book Is Organized . . . 1
0.1.4 Conventions Used in This Book . . . 2
0.1.5 A Note on the PDF Specification . . . 3
0.1.6 Three Decades of PDF: A Timeline . . . 3
0.1.7 Acknowledgments . . . 10

1 PDF Digital Signatures **13**
1.1 Signature Architecture . . . 13
1.1.1 Overview: What a PDF Signature Actually Is . . . 13
1.1.2 Signature Fields in the AcroForm Tree . . . 14
1.1.3 The Signature Dictionary (`/Type /Sig`) . . . 17
1.1.4 The `/Contents` Value: CMS SignedData . . . 20
1.1.5 The Signing Process: Step by Step . . . 23
1.1.6 Incremental Save: The Foundation of Multi-Signature . . . 25
1.1.7 Widget Annotations and Page Placement . . . 25
1.1.8 AcroForm `/SigFlags`: Document-Level Signature Metadata . . . 27
1.1.9 PDFBox API Mapping . . . 27
1.1.10 Common Mistakes and How to Avoid Them . . . 29
1.1.11 Key Points . . . 30
1.1.12 Specification References . . . 31

2 Security, Incidents & Outlook **33**
2.1 PDF Signature Attacks: A Complete Technical Analysis . . . 33
2.1.1 The Researchers . . . 33
2.1.2 Before Bochum: The State of PDF Signature Validation . . . 34
2.1.3 Attack Class 1: Universal Signature Forgery (USF) . . . 35
2.1.4 Attack Class 2: Incremental Saving Attack (ISA) . . . 39
2.1.5 Attack Class 3: Signature Wrapping Attack (SWA) . . . 44
2.1.6 Attack Class 4: Shadow Attacks (2021) . . . 47
2.1.7 Pre-Bochum Vulnerabilities: Earlier PDF Signature Issues . . . 51
2.1.8 Exploits in the Wild . . . 54
2.1.9 The Patch Response: What Changed . . . 55
2.1.10 Building a Robust Validator: Lessons from the Attacks . . . 56
2.1.11 A Note on Responsible Disclosure . . . 57
2.1.12 Summary . . . 58

0.1 Preface

PDF digital signatures are one of those technologies that seem straightforward until you actually have to implement them. You read the spec, write some code, run a test — and the signature validates in your tool but fails in Adobe Acrobat. Or it works in Acrobat but fails the EU's validation service. Or it works everywhere on Monday and breaks on Friday because a timestamp authority renewed its certificate.

If you've been there, this book is for you.

This is a technical reference for engineers, developers, and security researchers who need to understand PDF digital signatures at the deepest level — from the raw bytes in the file to the legal framework that gives those bytes legal standing across 27 EU member states. Every claim is backed by precise references to ISO 32000-2:2020, the ETSI PAdES standards, relevant RFCs, and the eIDAS regulation. Code examples use Apache PDFBox 3.0.0 and BouncyCastle 1.80 on Java 21, because that's what most of us actually use in production.

0.1.1 Who This Book Is For

You are a software engineer, a security researcher, or a technically curious person who needs to *understand* PDF signatures, not just use them. Maybe you're building a signing service. Maybe you're debugging why a customer's signature shows "invalid" in one viewer but "valid" in another. Maybe you're the person who got handed a government compliance checklist that says "PAdES-B-LTA" and nobody in your organization knows what that means.

We assume you know how to program, that you've encountered public-key cryptography before (even if the details are fuzzy), and that you're comfortable reading data structures. We do *not* assume you know anything about PDF internals, CMS, or the European regulatory landscape. Parts I and II build that foundation from scratch.

0.1.2 What This Book Is Not

This is not a tutorial. There are no "Hello World" signing examples in Chapter 1. If you need to sign a PDF in the next 20 minutes, copy the code from Chapter 28 and come back later to understand why it works.

This is not a product manual. We use PDFBox and BouncyCastle because they're open-source, widely deployed, and well-documented. The concepts apply equally to iText, OpenPDF, or any other library — the PDF specification doesn't care what language you write in.

This is not a legal guide. We explain the eIDAS regulation and its technical requirements in detail, but we are engineers, not lawyers. When legal precision matters — and with qualified electronic signatures, it always does — consult someone with a law degree.

0.1.3 How This Book Is Organized

The book is structured in six parts, each building on the previous:

Part I: Cryptographic Foundations (Chapters 1–6) starts from first principles. If you can explain the difference between RSA and ECDSA, between a certificate and a key pair, between CMS and PKCS#7 — skip ahead. If any of those distinctions are hazy, start here. We cover just

enough cryptography to make the rest of the book make sense, with a focus on the specific algorithms and structures you'll encounter in PDF signatures.

Part II: PDF Internals (Chapters 7–11) dissects the PDF file format itself. You'll learn how objects, cross-reference tables, and incremental updates work — because you cannot understand PDF signatures without understanding incremental saves. You'll also learn about AcroForm fields, annotations, and coordinate systems, because signature fields are form fields, signature appearances are annotations, and the coordinate system *will* trip you up.

Part III: PDF Digital Signatures (Chapters 12–18) is the heart of the book. This is where we take apart the `/Sig` dictionary key by key, trace the byte range byte by byte, and walk through the CMS structure field by field. We cover approval and certification signatures, visual appearances, validation logic, PAdES profiles, and long-term validation. If you only read one part of this book, read this one.

Part IV: eIDAS & Qualified Signatures (Chapters 19–23) enters the regulatory world. The European eIDAS regulation created a legal framework where a digital signature can have the same legal standing as a handwritten one — but only if it meets very specific technical requirements. We explain what those requirements are, how the EU Trusted List works, what a Qualified Trust Service Provider does, and how remote signing via the Cloud Signature Consortium API fits into the picture.

Part V: Security, Incidents & Outlook (Chapters 24–27) covers what can go wrong — and what has gone wrong. The Ruhr University Bochum research team published devastating attacks against PDF signature validation in 2019–2021. We analyze every attack technically, explain why it worked, and show how to defend against it. We also cover certificate authority breaches, industry oddities, and the emerging EUDI wallet.

Part VI: Code & Implementation (Chapters 28–31) is where theory meets production. Complete, tested Java code for signing, CMS construction, verification, and analysis — not snippets, but full classes you can drop into a project. We also provide test cases and reference PDFs for every scenario discussed in the book.

0.1.4 Conventions Used in This Book

PDF dictionary keys are written in monospace with a leading slash: `/SubFilter`, `/ByteRange`, `/Contents`. When we show a full dictionary, it's presented as a code listing with callout annotations explaining each key.

Spec references follow this pattern: "ISO 32000-2:2020 §12.8.1" means ISO 32000-2:2020, section 12.8.1. RFC references: "RFC 5652 — Cryptographic Message Syntax (CMS) §5" means RFC 5652, section 5. We use these abbreviations consistently throughout.

Code examples are Java 21 using PDFBox 3.0.0 and BouncyCastle 1.80. Every code listing compiles and runs — the source is in the book's repository alongside test cases that verify the examples.

Admonition blocks carry specific meaning:

Additional context, background, or alternative approaches.

Practical advice from experience — the kind of thing a senior colleague would tell you over coffee.

Something you must understand to avoid a specific class of bugs.

A common mistake or misunderstanding that leads to broken signatures.

A security-relevant issue that could lead to signature bypasses or compliance failures.

0.1.5 A Note on the PDF Specification

The PDF specification has a complicated history. Adobe published it as a proprietary format in 1993, released it as ISO 32000-1 in 2008, and then ISO 32000-2:2020 superseded it in 2020 with significant changes to the digital signature sections.

Throughout this book, we reference ISO 32000-2:2020 as the authoritative source. Where the behavior of older PDF versions matters (and for digital signatures, it often does — plenty of documents in the wild still use PDF 1.7 features), we note the differences explicitly.

The PAdES standards (ETSI EN 319 142) add an additional layer of requirements on top of ISO 32000-2. They don't replace the PDF spec — they constrain it. A PAdES-compliant signature is always a valid ISO 32000-2 signature, but not every valid ISO 32000-2 signature is PAdES-compliant. This distinction matters enormously in the EU, and increasingly, everywhere else.

0.1.6 Three Decades of PDF: A Timeline

PDF was born as a page description language for printing. Digital signatures were an afterthought — bolted on six years later in PDF 1.3, using a cryptographic framework (PKCS#7) that predated PDF itself. Understanding why PDF signatures work the way they do — and why they break the way they break — requires understanding the history that shaped them.

The following table traces every major milestone in the evolution of PDF and, specifically, the digital signature infrastructure built on top of it. Some of these are format changes. Some are regulatory events. Some are security incidents that forced the entire industry to rethink assumptions it had held for years. All of them left marks on the code you will write or debug.

Table 1: The evolution of PDF and PDF digital signatures, 1993–2026

Year	Event	What happened and why it matters
1993	**PDF 1.0** released (Acrobat 1.0)	Adobe published the Portable Document Format as a proprietary specification for reliable cross-platform document rendering. No forms, no interactivity, no signatures — just pages, text, images, and fonts. The file structure established here (header, body, cross-reference table, trailer) survives unchanged to this day. Every PDF you sign in 2026 still starts with `%PDF-1.x` or `%PDF-2.0` and ends with `%%EOF`.

Year	Event	What happened and why it matters
1996	**PDF 1.2** (Acrobat 3.0)	Introduced **AcroForm** — interactive form fields that users could fill in. This matters for signatures because signature fields *are* form fields. The `/AcroForm` dictionary, the field tree, widget annotations — all of the infrastructure that Chapter 9 dissects — was born here. PDF 1.2 also added Unicode support and Flate compression, both of which are ubiquitous in modern PDFs.
1999	**PDF 1.3** — digital signatures introduced (Acrobat 4.0)	The moment PDF gained the ability to carry cryptographic signatures. Adobe defined the `/Sig` dictionary type, the `/ByteRange` array, the `/Contents` hex string for the signature value, and the `/SubFilter` key with its initial value `adbe.pkcs7.detached`. The design decision to embed the CMS signature *inside* the PDF file (rather than as a detached sidecar) and to define the signed region as a byte range with a gap for the signature value itself — these were architectural choices made in 1999 that we still live with. Every quirk in Chapter 12 traces back to this release.
2001	**PDF 1.4** (Acrobat 5.0)	Added **transparency** (the imaging model's biggest change ever), 128-bit RC4 encryption, and **tagged PDF** for accessibility. For signatures: PDF 1.4 formalized the `adbe.pkcs7.sha1` SubFilter (where the SHA-1 hash of the entire document is embedded as the CMS content, rather than using a detached signature). This SubFilter is now deprecated but still appears in legacy documents. Acrobat 5 also introduced **certification signatures** (`/DocMDP` transform) — the distinction between "I approve this document" and "I certify this is the authoritative version" starts here.
2003	**PDF 1.5** (Acrobat 6.0)	Introduced **object streams** and **cross-reference streams** — a complete reworking of how PDF files store their internal structure. Instead of the classic ASCII cross-reference table, PDF 1.5 allows binary cross-reference data compressed inside stream objects. This matters for signatures because the byte range must cover the *entire* file structure, and cross-reference streams change where objects physically live in the file. PDF 1.5 also added **XFA forms** (Adobe's XML-based form format), which would become a persistent source of interoperability problems for signatures on XFA documents — a problem so annoying that ISO 32000-2:2020 deprecated XFA entirely.

Year	Event	What happened and why it matters
2005	**PDF 1.6** (Acrobat 7.0)	**AES-128 encryption** replaced the weak RC4-based encryption from earlier versions. Embedded file streams (attachments) and 3D content were added. For signatures: PDF 1.6 refined the interaction between encryption and signing — a signed, encrypted PDF requires careful handling to ensure the signature covers the encrypted content correctly. The `/NeedAppearances` flag behavior was also clarified, which matters because a missing appearance stream on a signature field causes some viewers to show a blank signature block.
2006	**PDF 1.7** (Acrobat 8.0)	The last version of PDF that Adobe defined unilaterally before handing the specification to ISO. PDF 1.7 solidified the **AES-256 encryption** scheme and finalized the AcroForm/XFA coexistence model. The vast majority of signed PDFs in the wild today are PDF 1.7 documents — not because of any technical limitation of PDF 2.0, but because template authors, form generators, and enterprise software have not yet migrated. When you debug a signature failure in production, you are almost certainly looking at a PDF 1.7 file.
2008	**ISO 32000-1:2008** — PDF becomes an ISO standard	Adobe donated the PDF 1.7 specification to ISO, making it an open international standard. The technical content was essentially identical to Adobe's PDF Reference 1.7, but the governance changed: future changes would go through the ISO committee process, not Adobe's product team. For signatures, this was the moment PDF digital signatures gained the credibility of an ISO-backed specification — a prerequisite for government and regulated-industry adoption.

Year	Event	What happened and why it matters
2009	**PAdES** — ETSI TS 102 778 (Parts 1–5)	The European Telecommunications Standards Institute published the first **PDF Advanced Electronic Signatures** standards. PAdES defined profiles for how CMS signatures should be embedded in PDF to meet European legal requirements: which signed attributes are mandatory (ESS signing-certificate-v2), which SubFilter values to use (`ETSI.CAdES.detached`), and how to embed timestamps, revocation data, and long-term validation information. PAdES didn't replace ISO 32000 — it constrained it. A PAdES-compliant signature is always a valid ISO 32000 signature, but the reverse is not true. This distinction — and the interoperability problems it causes when a PDF viewer validates against ISO 32000 rules but not PAdES rules — is a recurring theme in this book (Chapters 17 and 26).
2011	**DigiNotar breach** — CA infrastructure crisis	A Dutch certificate authority, DigiNotar, was completely compromised by an attacker who issued over 500 fraudulent certificates — including certificates for google.com, mozilla.org, and intelligence agencies. The certificates were used in man-in-the-middle attacks against Iranian dissidents. Every major browser vendor revoked trust in DigiNotar within weeks; the company went bankrupt within months. For PDF signatures: DigiNotar was a wake-up call about the fragility of the certificate trust model that all digital signatures depend on. If a CA can be compromised, any signature issued by that CA's certificates becomes suspect. This incident accelerated the adoption of Certificate Transparency logs and tighter CA audit requirements — both of which affected the trust infrastructure behind PDF signatures. Chapter 25 covers this and other CA breaches in detail.

Year	Event	What happened and why it matters
2012	**Adobe Approved Trust List (AATL)** formalized	Adobe formalized its **AATL** program — a curated list of root certificates that Acrobat trusts for signature validation. If your signing certificate chains up to an AATL root, Acrobat shows a green checkmark. If it doesn't — even if the certificate is perfectly valid, issued by a reputable CA, and chains to a trust anchor in your OS trust store — Acrobat shows a warning. This created a de facto monopoly on "valid" PDF signatures: to get a green checkmark in the world's dominant PDF viewer, you need an AATL-listed certificate, which costs significantly more than a standard code-signing certificate. The AATL remains one of the most contentious aspects of the PDF signature ecosystem (Chapter 26).
2014	**eIDAS Regulation** (EU 910/2014) enacted	The European Union passed the **Electronic Identification, Authentication and Trust Services** regulation, creating a legal framework where digital signatures can have the same legal standing as handwritten signatures — but only if they meet strict technical requirements. eIDAS defined three tiers: **electronic signatures** (any electronic indication of signing intent), **advanced electronic signatures** (uniquely linked to the signatory, capable of identifying them, under their sole control, linked to the data so any change is detectable), and **qualified electronic signatures** (advanced + created by a qualified device + based on a qualified certificate issued by a qualified trust service provider). Only QES has automatic legal equivalence to a handwritten signature across all EU member states. PAdES became the primary technical mechanism for creating eIDAS-compliant signatures in PDF. Chapters 19–23 cover the entire eIDAS ecosystem.

Year	Event	What happened and why it matters
2016	**eIDAS fully effective** (July 1, 2016)	The eIDAS regulation became fully effective across all EU member states, with the **EU Trusted List (EUTL)** operational. The EUTL is a machine-readable, cryptographically signed list of every Qualified Trust Service Provider in the EU — the authoritative source for determining whether a signing certificate qualifies for the highest legal tier. For developers: if your application needs to validate whether a PDF signature is a qualified electronic signature, you must check the signing certificate against the EUTL, not just against a generic trust store. The EUTL XML schema, its signature validation, and the LOT (List of Trusted Lists) hierarchy are covered in Chapter 20.
2017	**ISO 32000-2:2017** — PDF 2.0, first edition	The first major revision of the PDF specification under ISO governance. PDF 2.0 deprecated XFA forms, removed several legacy features, and made significant changes to the digital signature sections. Notably: the `adbe.pkcs7.sha1` SubFilter was deprecated (SHA-1 is cryptographically broken for collision resistance since the SHAttered attack of February 2017), and the specification added the `ETSI.RFC3161` SubFilter for document-level timestamps. PDF 2.0 also clarified the byte range coverage rules and tightened the requirements around incremental updates after signing — changes that were partly motivated by early reports of the signature validation problems that Bochum would systematically expose two years later.
2019	**"1 Trillion Dollar Refund"** — Bochum attacks (CCS 2019)	The Ruhr University Bochum team published their landmark paper at ACM CCS 2019, systematically breaking PDF signature validation in every major viewer. They identified three attack classes: **Universal Signature Forgery (USF)** — crafting a signed PDF with a garbage or empty signature value that viewers accepted as valid; **Incremental Saving Attack (ISA)** — appending unsigned changes to a signed PDF that viewers failed to flag; and **Signature Wrapping Attack (SWA)** — relocating the signature's byte range to point at attacker-controlled data. Of 22 desktop viewers tested, all were vulnerable to at least one attack. The paper title referenced the fact that signed PDFs are used for tax refund claims, insurance payouts, and financial contracts — if signatures could be forged, the financial exposure was enormous. This research is the subject of Chapter 24.

Year	Event	What happened and why it matters
2020	**ISO 32000-2:2020** — PDF 2.0, second edition	The second edition of PDF 2.0 incorporated corrections and clarifications, including tightened language around signature validation motivated by the Bochum attacks. In the same year, Adobe issued **CVE-2020-9592** and **CVE-2020-9596** and patched Acrobat against USF, ISA, and SWA. Foxit, Nitro, LibreOffice, Okular, and every other major viewer released their own patches. The PAdES standards were also updated (ETSI EN 319 142-1 V1.1.1) to align with the second edition of ISO 32000-2.
2021	**Shadow Attacks** (NDSS 2021)	The Bochum team published a follow-up: **Shadow Attacks**. Unlike the 2019 attacks (which modified a PDF *after* signing), Shadow Attacks prepared malicious content *before* the document was signed. The attacker created a PDF with hidden content (invisible text, overlapping images, replaced form fields) that the signer could not see during signing — but that became visible when the recipient opened the document. The signature validated correctly because the signed bytes were genuinely signed by the legitimate signer. The attack exploited the gap between what the signer *saw* and what the bytes *contained* — a fundamental problem in any visual-document signing model. Three variants were demonstrated: **Hide** (hiding content behind overlapping elements), **Replace** (swapping visible content via interactive form features), and **Hide-and-Replace** (combining both). Again, all major viewers were vulnerable.
2022	**ETSI EN 319 142-1 V1.2.1** — PAdES update	ETSI updated the PAdES standard to align with ISO 32000-2:2020 and to incorporate lessons from the Bochum attacks. The update clarified requirements around signature scope validation, incremental update handling, and the relationship between the byte range and the visible document content. It also formalized the PAdES-B-LTA profile's requirements for archival timestamps in the DSS (Document Security Store) — the mechanism that enables long-term validation decades after the signing certificate has expired.

Year	Event	What happened and why it matters
2024	**eIDAS 2.0** (EU 2024/1183) enacted	The EU adopted the revised eIDAS regulation, which introduced the **European Digital Identity (EUDI) Wallet** — a smartphone-based identity wallet that every EU member state must offer to its citizens by 2026. The EUDI wallet will carry government-issued identity attestations (PID — Person Identification Data) and qualified electronic attestations of attributes (QEAA), enabling citizens to sign documents with qualified electronic signatures from their phone. This represents the most ambitious attempt to make QES mainstream — moving it from specialized HSM-backed signing services to consumer smartphones. The Architecture Reference Framework (ARF) defines the technical specifications. Chapter 27 covers the EUDI wallet and its impact on PDF signing.
2025–26	**EUDI wallet pilots & deployment**	EU member states are conducting large-scale pilot programs for the EUDI wallet across sectors: banking (identity verification), travel (digital travel credentials), education (diplomas), healthcare (prescriptions), and government services. The pilots test the wallet's signing capabilities, including PAdES-B-LTA signature creation from mobile devices, remote QSCD integration, and cross-border signature validation. The Cloud Signature Consortium (CSC) API — the standard interface for remote signing — is being adapted for wallet integration. The outcome of these pilots will determine whether QES becomes a mainstream consumer technology or remains a specialized enterprise tool.

The table omits minor point releases and focuses on the events that changed what developers need to know. If you are working with PDF signatures today, every row in that table has left its fingerprint on the code you are writing — whether it's the byte range gap from 1999, the PAdES constraints from 2009, the trust model questions raised by DigiNotar in 2011, or the validation rewrites forced by Bochum in 2019–2021.

0.1.7 Acknowledgments

This book would not exist without the open-source communities that make PDF signature work accessible to everyone. The **Apache PDFBox** team — particularly Andreas Lehmkühler, Tilman Hausherr, and the many contributors who maintain the signing infrastructure — have built the most widely used open-source PDF library in the Java ecosystem. The **Legion of the Bouncy Castle** (yes, that's their actual name) gave us BouncyCastle, which provides the CMS and X.509 implementations that most Java signing code depends on, whether it knows it or not.

Special acknowledgment goes to the security researchers at **Ruhr University Bochum** — Vladislav Mladenov, Christian Mainka, Karsten Meyer zu Selhausen, Martin Grothe, and Jörg Schwenk — whose systematic analysis of PDF signature validation between 2019 and 2021 exposed fundamental flaws in how every major PDF viewer handled signatures. Their papers — *"1 Trillion Dollar Refund: How To Spoof PDF Signatures"* (CCS 2019), *"Shadow Attacks: Hiding and Replacing Content in Signed PDFs"* (NDSS 2021), and several follow-ups — demonstrated that attackers could forge signatures, hide content changes behind valid signatures, and bypass validation in Adobe Acrobat, Foxit Reader, and dozens of other viewers. The industry patched, but the research fundamentally changed how we think about PDF signature security. Their work is cited throughout this book, and Chapter 24 is dedicated to a technical analysis of their attacks.

What they found was this: PDF viewers did not actually verify what they claimed to verify. The Bochum team identified three major attack classes. **Universal Signature Forgery (USF)** showed that some viewers only checked whether a signature *existed* — not whether its cryptographic value was correct. An attacker could craft a PDF with an empty or garbage `/Contents` value, and viewers like Adobe Acrobat DC (before the patch) would display it as "signed and valid." **Incremental Saving Attack (ISA)** exploited the incremental update mechanism that PDF signatures depend on: an attacker could append a new revision to a signed PDF — changing text, adding pages, replacing content entirely — and because viewers did not properly check whether the appended changes fell outside the signed byte range, the signature still showed as valid. **Signature Wrapping Attack (SWA)** relocated the signed content within the file so that the byte range pointed at attacker-controlled data while the original signature remained structurally present. The follow-up **Shadow Attacks** paper (NDSS 2021) went further: an attacker could prepare a PDF *before* it was signed, embedding hidden content that would only become visible after signing — the signer would see one document, but the recipient would see another, and the signature would validate on both views.

The team tested 22 desktop PDF viewers and 7 online validation services. Every single one was vulnerable to at least one attack class. Adobe issued CVE-2020-9592 and CVE-2020-9596 and patched Acrobat in May 2020. Foxit, Nitro, LibreOffice, and every other major viewer followed with their own patches. The research forced a fundamental rethinking of PDF signature validation — in particular, how viewers handle incremental updates after signing, how byte range coverage is verified, and how the relationship between the CMS signature and the actual document bytes is validated. Before Bochum, most viewers treated signature validation as a checkbox. After Bochum, it became a security-critical code path that required adversarial thinking.

The **European Telecommunications Standards Institute (ETSI)** deserves credit for the PAdES standards that brought PDF signatures into the regulated world. Whatever one may think about the complexity of ETSI EN 319 142, it solved the real problem of making PDF signatures legally interoperable across borders.

And the PDF specification itself is the product of hundreds of engineers at Adobe, ISO, and ETSI who somehow managed to build a digital signature framework into a page description language originally designed for printing. That it works as well as it does is a testament to their effort. That it has the quirks it has is a testament to the fact that three decades of backward compatibility leaves marks.

Chapter 1

PDF Digital Signatures

1.1 Signature Architecture

This chapter dissects the internal architecture of PDF digital signatures as specified in ISO 32000-2:2020 §12.8. We examine every dictionary, every key, and every byte — from the AcroForm field tree down to the raw CMS `SignedData` blob embedded in `/Contents`.

But more importantly, we talk about what actually matters when you're staring at a broken signature at 2 AM, wondering why Adobe says "invalid" while your code says "fine."

1.1.1 Overview: What a PDF Signature Actually Is

Here's the thing most people get wrong about PDF signatures: they think of them as something *attached to* a document, like a wax seal on an envelope. They're not.

A PDF digital signature is a set of **PDF objects embedded within the document itself**. The signature *is part of the document*. This seemingly minor architectural choice has profound consequences — it's why PDF signatures are simultaneously powerful and maddening, why they survive copy operations but break on re-saves, and why you can have a perfectly valid signature on a document that's been modified after signing (yes, really).

The four pieces of a PDF signature:

1. A **signature field** (`PDSignatureField`) in the AcroForm field tree — the form field that "holds" the signature
2. A **signature dictionary** (`/Type /Sig`) — the actual cryptographic payload and metadata
3. A **widget annotation** — the visual rectangle on a page (may be zero-size for invisible signatures)
4. An **appearance stream** (`/AP`) — what the viewer renders in the signature rectangle

The signature field is a form field like any other (`/FT /Sig`). The signature dictionary is the *value* of that field (`/V`). An unsigned field has `/V` absent or null — the field exists but has no signature value yet.

Think of it like an empty checkbox on a paper form. The box is there, waiting to be checked. A document author can place signature fields in a PDF template, and signers fill them in later — each one independently, at different times, possibly on different continents.

When you encounter a PDF with signature problems, start here. Open the document in a COS-level viewer (like PDFalyzer, or even a hex editor) and check:

1. Does the AcroForm exist? (Some PDFs have signature fields floating without an AcroForm — instant headache.)
2. Does `/SigFlags` include bit 2 (AppendOnly)? If not, any editor can destroy all signatures with a simple save.
3. Is the `/V` entry present on the signature field? If absent, the field is unsigned.
4. Does the widget actually have a page reference? Some tools create orphaned widgets.

This five-minute checklist saves hours of debugging.

1.1.2 Signature Fields in the AcroForm Tree

> A signature field (field type Sig) shall represent a digital signature that may or may not have a signature value.
>
> — ISO 32000-2:2020 §12.7.4.5

Signature fields live in the document's interactive form structure:

1.1.2.1 The SigFlags Trap

The `/SigFlags` entry is one of those things that's easy to overlook and devastating to get wrong.

Bit	Name	Effect
1 (value 1)	`SignaturesExist`	Tells the viewer "this document contains at least one signature field." Conforming readers **shall not** allow saving in a way that invalidates existing signatures.
2 (value 2)	`AppendOnly`	The document **shall** be saved using incremental updates only (ISO 32000-2:2020 §12.7.4.5). This is the mechanism that protects existing signatures from being destroyed by a full rewrite.

Setting `/SigFlags` to 3 (both bits) is mandatory when a document contains signatures. If bit 2 is missing, a naive PDF editor may do a full save and destroy all signatures. Many real-world PDFs get this wrong.

Here's what happens in practice: someone creates a PDF with LibreOffice, adds a signature field, signs it — and LibreOffice doesn't set bit 2. The document gets emailed to a colleague who opens it in some random PDF editor to add an annotation, hits save, and the editor does a full rewrite. Every signature is now invalid. The colleague has no idea what happened. The signer gets an angry phone call.

The fix is always the same: if you're building a tool that creates signature fields, set `/SigFlags` to 3 the moment any field has a value. And if you're building a tool that edits PDFs, check for `/SigFlags` bit 2 before saving — if it's set, you *must* use incremental save. If your tool doesn't support incremental save… well, you need to support it now. Welcome to PDF.

1.1.2.2 Field Dictionary Structure

A signature field's COS dictionary looks like this. Every key matters, and I'll explain why:

```
<<
  /Type /Annot
  /Subtype /Widget
  /FT /Sig
  /T (Signature1)
  /V 42 0 R
  /Rect [100 500 300 550]
  /AP << /N 43 0 R >>
  /P 7 0 R
  /Lock <<
    /Type /SigFieldLock
    /Action /All
  >>
  /SV <<
    /Type /SV
    /Filter /Adobe.PPKLite
    /SubFilter [/adbe.pkcs7.detached /ETSI.CAdES.detached]
    /DigestMethod [/SHA256 /SHA384 /SHA512]
    /Reasons [(Approved)(Reviewed)]
    /MDP <<
      /P 2
    >>
  >>
>>
```

- Merged field+widget — this is very common in simple forms. The spec (ISO 32000-2:2020 §12.5.6.19) allows splitting into separate objects, and some sophisticated tools do, but most don't bother.
- Field type — `/Sig` marks this as a signature field. This is non-negotiable. If you see `/FT /Tx` on something that's supposed to be a signature, someone made a mistake.
- Partial field name — used to identify the field programmatically. This is how your code finds "the signature field called Signature1."
- Reference to the signature dictionary — the cryptographic payload. If this is absent, the field is unsigned. This is the key entry.
- Widget rectangle in page coordinates — lower-left x, lower-left y, upper-right x, upper-right y. If `[0 0 0 0]`, the signature is invisible.
- Appearance stream — what the viewer draws. Without this, many viewers show a generic placeholder. Adobe Acrobat is particularly opinionated about appearances.
- Page reference — which page this widget is on. Some poorly generated PDFs omit this, and then viewers have to guess. Don't be that tool.
- **Lock dictionary** — restricts what can change after signing (see ???). This is how approval signatures can lock specific fields.
- **Seed value dictionary** — constrains *how* the field may be signed: which algorithms, which filters, what reasons. More on this below.

1.1.2.3 Seed Value Dictionary (`/SV`): The Unsung Hero

> The seed value dictionary provides constraint information that shall be used at the time the signature is applied.
>
> — ISO 32000-2:2020 §12.7.5.5

The seed value dictionary is one of the most powerful and underused features in the entire PDF signature specification. Most people don't even know it exists, which is a shame, because it solves a problem that plagues every organization deploying PDF signatures at scale: **how do you ensure signers use the right algorithm, the right format, and the right handler?**

Key	Type	Purpose
`/Filter`	name	Required signature handler (e.g., `/Adobe.PPKLite`). Use this to ensure your documents work with specific software.
`/SubFilter`	array of names	Acceptable signature formats. Set this to `[/ETSI.CAdES.detached]` if you need PAdES compliance. The signer's software **must** use one of these formats.
`/DigestMethod`	array of names	Acceptable hash algorithms. Set this to `[/SHA256 /SHA384 /SHA512]` — and for the love of all that is holy, **do not include `/SHA1`**. It's 2026. SHA-1 has been broken since 2017.
`/Reasons`	array of strings	Pre-defined reason strings the signer must choose from. Great for audit trails — instead of "asdf" in the reason field, signers pick from "Approved", "Reviewed", "Authorized".
`/MDP`	dictionary	Contains `/P` — the DocMDP permission level this signature must enforce. This is how a template author says "whoever signs this field must also lock the document."
`/TimeStamp`	dictionary	URL of a timestamp server (`/URL`) and whether it's required (`/Ff` bit 1). If you need PAdES-B-T, set this. The signer's software will contact the TSA automatically.
`/LegalAttestation`	array of strings	Legal attestation strings — rarely used, but available if you need legal boilerplate attached to the signature.
`/Ff`	integer	Flags indicating which seed values are **required** (vs. recommended). If bit 1 is set on a constraint, it's mandatory.

Practical advice for template authors:

If you're creating PDF templates that others will sign, use seed values aggressively. Don't trust signers to pick the right options — they won't. A financial services company once sent us PDFs where half the signatures used SHA-1 because some signers had old software and

nobody constrained the algorithm. Those signatures were technically valid but would fail compliance audits.

Set `/DigestMethod` to `[/SHA256]`, set `/SubFilter` to `[/ETSI.CAdES.detached]`, and set the `/Ff` flags to make them mandatory. Your future self will thank you.

1.1.3 The Signature Dictionary (`/Type /Sig`)

The signature dictionary is the heart of a PDF digital signature. It's referenced from the field's `/V` entry, and it's where the real action is. Everything else — the field, the widget, the appearance — is just scaffolding. This dictionary is where the cryptographic proof lives.

```
<<
  /Type /Sig
  /Filter /Adobe.PPKLite
  /SubFilter /ETSI.CAdES.detached
  /ByteRange [0 15000 15500 34500]
  /Contents <308206A7...00000000>
  /M (D:20260306120000+00'00')
  /Name (John Doe)
  /Location (Vienna, Austria)
  /Reason (Approved)
  /ContactInfo (john@example.com)
  /Reference [
    <<
      /Type /SigRef
      /TransformMethod /DocMDP
      /TransformParams <<
        /Type /TransformParams
        /P 2
        /V /1.2
      >>
      /DigestMethod /SHA256
    >>
  ]
  /Prop_Build <<
    /App << /Name /PDFalyzer >>
    /Filter << /Name /Adobe.PPKLite >>
  >>
>>
```

- Dictionary type identifier
- **Filter** — the signature handler name. In theory, this identifies which software can process the signature. In practice, it's always `/Adobe.PPKLite`. Always. Even when the signing software has nothing to do with Adobe. The name stuck because Adobe defined the original signature spec in 1999 and everyone just... went with it.
- **SubFilter** — the actual signature format. *This* is the important one — see SubFilter Values: A Brief History of Getting It Right.
- **ByteRange** — which bytes of the file are signed. The most important array in the entire dictionary. See ???.

- **Contents** — the hex-encoded CMS `SignedData` blob, padded with zeros. This is the actual cryptographic signature.
- Signing time in PDF date format. **Do not trust this.** It's set by the signer's machine. Use the timestamp in the CMS attributes for authoritative time.
- Signer's name. **Do not trust this either.** It's free text. The authoritative name is in the X.509 certificate inside `/Contents`.
- Signing location. Informational, optional, unverified.
- Signing reason. Informational, optional, unverified.
- Contact info. Informational, optional, you see the pattern.
- **Reference array** — transform methods like DocMDP, FieldMDP, UR. This is where permission restrictions are defined. See ???.
- Build properties — identifies the software that created the signature. Surprisingly useful for debugging.

The `/M`, `/Name`, `/Location`, `/Reason`, and `/ContactInfo` fields are **unauthenticated metadata**. Yes, they're part of the signed bytes. Yes, they can't be changed after signing. But they're set *before* signing, by whoever controls the signing process. If a malicious signer puts "Barack Obama" in the `/Name` field and signs with a self-signed certificate, the signature will be structurally valid. **The only trustworthy identity information is the X.509 certificate in `/Contents`.** Never display `/Name` to users as if it were verified identity. This mistake is shockingly common in PDF viewer implementations.

The `/Prop_Build` dictionary is your friend when debugging.

When a signature doesn't validate, the first thing I check is `/Prop_Build`. It tells you which software created the signature. If it says `/iText` with a version from 2015, you know you might be dealing with an old CMS structure. If it says `/Adobe Acrobat` and the signature is invalid, something is genuinely wrong because Adobe's own tool should produce signatures that Adobe validates. If `/Prop_Build` is missing entirely, the signing software was lazy — which tells you something about the quality of the rest of the signature, too.

1.1.3.1 SubFilter Values: A Brief History of Getting It Right

The `/SubFilter` value determines how the `/Contents` bytes are structured. Getting this right is the difference between "signature works everywhere" and "signature works in Adobe but nowhere else" (or vice versa).

The history of SubFilter values is essentially the history of PDF signatures trying — and sometimes failing — to keep up with cryptographic best practices:

SubFilter	Standard	Description
`/adbe.x509.rsa_sha1`	PDF 1.3+	**Deprecated. Do not use.** Raw RSA signature with the certificate in a separate `/Cert` key instead of inside `/Contents`. No CMS wrapper. SHA-1 only. This was PDF's first attempt at digital signatures in 1999. It made sense at the time. It doesn't anymore.

SubFilter	Standard	Description
`/adbe.pkcs7.detached`	PDF 1.3+	CMS `SignedData` with detached content. The workhorse format — widely supported since PDF 1.3. The signed bytes are the PDF byte range, not embedded in CMS. If you need maximum compatibility with older software, this is your format. Defined in ISO 32000-2:2020 §12.8.3.3.
`/adbe.pkcs7.sha1`	PDF 1.3+	**Deprecated. Do not use.** CMS `SignedData` where the SHA-1 digest of the byte range is *encapsulated* in the CMS. This is the worst of both worlds: SHA-1 (broken) and encapsulated content (unnecessary complexity). Nobody misses this format.
`/ETSI.CAdES.detached`	PDF 2.0 / PAdES	CMS `SignedData` with mandatory CAdES signed attributes, specifically the `signing-certificate-v2` attribute. Required for PAdES-B-B and higher. Defined in ETSI EN 319 142-1 V1.1.1 (2016-04) §5.1. **This is the modern standard. Use this.**
`/ETSI.RFC3161`	PDF 2.0 / PAdES	RFC 3161 timestamp token — not a signature, but a document timestamp. Used for PAdES-B-T and long-term archival. Defined in ETSI EN 319 142-1 V1.1.1 (2016-04) §5.4. You'll encounter these when dealing with LTV (Long-Term Validation).

Here's a trap that catches people all the time: Adobe Acrobat and most viewers accept *all* SubFilter values for backward compatibility. Your signature will "work" in Acrobat regardless of which SubFilter you use. But **only** `/ETSI.CAdES.detached` is valid for PAdES-compliant signatures under eIDAS. If you need legal standing in the EU — and increasingly, that's everyone — this is the only acceptable value. Don't let "it works in Acrobat" lull you into using `/adbe.pkcs7.detached` for new signatures. Acrobat is not the arbiter of legal validity; the eIDAS regulation is.

The compatibility question everyone asks:

"Can I use `/ETSI.CAdES.detached` if my users have old PDF readers?"

Yes. The CMS structure is identical to `/adbe.pkcs7.detached` at the container level. Old readers that don't understand the SubFilter name will typically fall back to parsing the `/Contents` as generic CMS/PKCS#7 — and it will work. The difference is one signed attribute (`signing-certificate-v2`), which old readers simply ignore.

The only scenario where it breaks: truly ancient software (pre-2010) that strictly checks the SubFilter name against a hardcoded whitelist and rejects unknown values. If your users are running PDF readers from 2008, they have bigger problems than SubFilter compatibility.

1.1.4 The `/Contents` Value: CMS SignedData

The `/Contents` entry is a **hex-encoded byte string** containing a DER-encoded CMS `SignedData` structure (RFC 5652 — Cryptographic Message Syntax (CMS) §5).

This is where the actual cryptographic signature lives. Everything else in the signature dictionary is metadata. This is the payload.

1.1.4.1 Why Hex-Encoded?

PDF strings can be literal `(…)` or hex `<…>`. The hex form is used because CMS blobs contain arbitrary binary data (DER-encoded ASN.1), and literal strings would need extensive escaping for bytes like `\(`, `\)`, `\\`. Hex encoding doubles the size but is safe and unambiguous.

A typical `/Contents` value looks like `<308206A7…several thousand hex characters…0000000000>`. The leading bytes (`3082…`) are the DER-encoded ASN.1 SEQUENCE tag, and the trailing zeros are padding. Which brings us to one of the more elegant hacks in the PDF specification:

1.1.4.2 Pre-allocation: The Chicken-and-Egg Problem

Here's the fundamental problem with PDF signatures:

1. The signature covers the file's bytes (including the signature dictionary itself)
2. But the signature dictionary must contain the CMS blob
3. But the CMS blob can only be computed *after* you know which bytes to sign
4. But you can't know which bytes to sign until the dictionary is written

The solution is a trick that every PDF signing implementation uses: **pre-allocate** a large enough `/Contents` value filled with zeros, write the file, *then* overwrite the zeros with the actual CMS bytes:

The pre-allocated size must be estimated accurately, and this is where things go wrong in the real world:

- **Too small** — the CMS blob doesn't fit — signing fails. You'll get an exception from PDFBox and no output file. This is the most common "my signing suddenly broke" bug, usually triggered by adding a certificate chain or a timestamp that makes the CMS blob bigger than expected.
- **Too large** — wasted bytes, but the signature is valid. A few KB of zeros at the end of the file never hurt anyone.

Always err on the side of too large. Here are sensible defaults:

Scenario	Hex Size	Bytes
Basic signature (no chain, no timestamp)	`0x2500` (PDFBox default)	~9 KB
Signature with certificate chain	`0x4000`	~16 KB
PAdES-B-T (with RFC 3161 timestamp)	`0x6000`	~24 KB

Scenario	Hex Size	Bytes
PAdES-B-LT (embedded OCSP + CRLs)	`0x18000`	~96 KB
PAdES-B-LTA (archival, large CRL)	`0x28000`	~160 KB

I've seen production systems fail because someone used the PDFBox default (`0x2500`) for PAdES-B-T signatures. The first 500 signatures worked fine because the TSA responses were small. Then the TSA renewed its certificate with a longer chain, the responses grew by 2 KB, and every signing operation started failing on a Friday afternoon. Set it to `0x6000` minimum and forget about it.

1.1.4.3 CMS SignedData: The Cryptographic Core

The CMS blob inside `/Contents` follows RFC 5652 — Cryptographic Message Syntax (CMS) §5. If you've worked with S/MIME email signatures or code signing, this structure will look familiar — it's the same `SignedData` format used across the entire PKI ecosystem:

```
SignedData ::= SEQUENCE {
    version            CMSVersion,
    digestAlgorithms   DigestAlgorithmIdentifiers,
    encapContentInfo   EncapsulatedContentInfo,
    certificates   [0] IMPLICIT CertificateSet OPTIONAL,
    crls           [1] IMPLICIT RevocationInfoChoices OPTIONAL,
    signerInfos        SignerInfos
}
```

- Version: 1 for basic CMS, 3 if attribute certificates are present
- Set of digest algorithms used (typically just `{SHA-256}`)
- Content type: `id-data` (1.2.840.113549.1.7.1) with **absent** content — this is what "detached" means. The signed data (the PDF byte range) is not inside the CMS structure. It's outside, in the PDF file itself.
- Certificates — the signer's certificate and optionally the full chain (intermediates, possibly root). **Always include the full chain.** I know it makes the blob bigger. I know storage is a concern. Do it anyway. A signature without a chain is a signature that can only be validated by someone who already has all your certificates. That's almost nobody.
- CRLs — rarely embedded here in the modern PAdES world. In PAdES-B-LT and later, revocation data goes in the DSS dictionary instead.
- Signer information — the actual signature value and signed attributes. This is where the cryptography lives.

1.1.4.3.1 SignerInfo: Where the Cryptography Lives

```
SignerInfo ::= SEQUENCE {
    version                   CMSVersion,
    sid                       SignerIdentifier,
    digestAlgorithm           DigestAlgorithmIdentifier,
    signedAttrs           [0] IMPLICIT SignedAttributes OPTIONAL,
```

```
    signatureAlgorithm       SignatureAlgorithmIdentifier,
    signature                SignatureValue,
    unsignedAttrs        [1] IMPLICIT UnsignedAttributes OPTIONAL
}
```

- Identifies the signer's certificate — either by issuer DN + serial number, or by subject key identifier. Both work. Issuer+serial is more traditional; subject key identifier is more robust when certificates are reissued.
- Hash algorithm used to digest the PDF byte range. SHA-256 is the minimum acceptable. SHA-384 or SHA-512 if you're paranoid or work in defense.
- **Signed attributes** — authenticated metadata. See the critical attributes table below. These are *signed*, meaning any modification invalidates the signature.
- Signature algorithm (e.g., SHA256withRSA, SHA256withECDSA). Note: the *signature* is computed over the DER-encoded signed attributes, not directly over the PDF bytes. This is a CMS subtlety that trips up many implementers.
- The actual cryptographic signature bytes.
- **Unsigned attributes** — unauthenticated extensions. Timestamps go here.

1.1.4.3.2 The Signed Attributes That Matter

Attribute	OID	Purpose
`content-type`	1.2.840.113549.1.9.3	Must be `id-data`. **Required** by CMS when signed attributes are present. Forgetting this is a classic implementation bug — the signature appears valid in some tools but fails in others.
`message-digest`	1.2.840.113549.1.9.4	SHA-256 hash of the PDF byte range. **Required.** This is what's actually verified during validation. If this hash doesn't match the file bytes, the signature is invalid. Full stop.
`signing-time`	1.2.840.113549.1.9.5	Claimed signing time. Not authoritative — it's whatever the signer's clock said. For authoritative time, you need a timestamp (see unsigned attributes). Optional, but almost everyone includes it.
`signing-certificate-v2`	1.2.840.113549.1.9.16.2.47	Hash of the signer's certificate (SHA-256). **Required for PAdES / CAdES.** Defined in RFC 5035. This single attribute prevents certificate substitution attacks — an attacker can't swap in a different certificate without breaking the signature.
`algorithm-protection`	1.2.840.113549.1.9.52	Protects against algorithm substitution attacks (RFC 6211). Recommended but not required. Good hygiene to include.

The `signing-certificate-v2` attribute is what makes the difference between `/adbe.pkcs7.detached` and `/ETSI.CAdES.detached`.

Without it: plain CMS (PKCS#7) — vulnerable to certificate substitution attacks. With it: CAdES — the signer's certificate is bound to the signature by hash.

This single attribute is the gateway to PAdES compliance. It's about 50 bytes in the CMS structure. There is no reason not to include it, even if you're using `/adbe.pkcs7.detached` as your SubFilter.

Certificate substitution attacks are not theoretical. In 2019, researchers at Ruhr University Bochum demonstrated practical attacks against multiple PDF viewers that exploited the absence of certificate binding. The fix was trivially simple: check `signing-certificate-v2`. Several major viewers had to be patched.

1.1.4.3.3 Unsigned Attributes: The Afterthought That Became Essential

Attribute	OID	Purpose
`signature-time-stamp`	1.2.840.113549.1.9.16.2.14	RFC 3161 timestamp token over the signature value. Required for PAdES-B-T. Provides authoritative proof of signing time from a trusted TSA. This is the only way to prove *when* a signature was made.
`certificate-values`	1.2.840.113549.1.9.16.2.23	Full certificate chain values. Used in CAdES-X-Long. In PAdES, these go in the DSS dictionary instead.
`revocation-values`	1.2.840.113549.1.9.16.2.24	OCSP responses and CRLs. Used in CAdES-X-Long. In PAdES, these go in the DSS dictionary instead.

The timestamp attribute deserves special attention. Unsigned attributes are, by definition, not protected by the signature — they can be added after signing without invalidating anything. This is *by design*. A timestamp proves that the signature existed at a certain time, and it's intentionally added after the signature is created (because you need the signature value to timestamp it).

This is also why you should never put anything security-critical in unsigned attributes that isn't self-authenticating (like a timestamp token, which has its own signature from the TSA).

1.1.5 The Signing Process: Step by Step

The process of creating a PDF digital signature is intricate because the signature must cover bytes that include the signature dictionary itself — a chicken-and-egg problem solved by the `/Contents` pre-allocation we discussed above.

Here's the full sequence, and understanding it is essential for debugging:

1.1.5.1 Step-by-Step Detail

Step	Detail
1	**Create or locate the signature field.** If the document already has an unsigned field (`/FT /Sig` with no `/V`), use it. Otherwise, create a new field in the AcroForm `/Fields` array with a widget annotation on the desired page. *Practical note:* if the document was prepared by someone else (a template), always prefer using existing unsigned fields. Creating new fields in a document that already has signatures is technically possible via incremental save, but it makes some validators nervous.
2	**Build the signature dictionary** with placeholder values. `/ByteRange` is set to `[0 0 0 0]` (will be overwritten). `/Contents` is filled with `00` bytes at the estimated maximum size. All other keys (`/Filter`, `/SubFilter`, `/M`, `/Name`, `/Reason`, `/Reference`) are set to their final values *now* — they become part of the signed bytes and can't change later.
3	**Write the PDF using incremental save.** The new objects (signature dict, updated field, updated xref) are appended after the existing `%%EOF`. This is critical — a full rewrite would invalidate any existing signatures. *This is non-negotiable.* Even if the document has no prior signatures, use incremental save. It's the only safe habit.
4	**Compute actual byte offsets.** After writing, the exact byte positions of the `/Contents` hex string are known. Update `/ByteRange` to `[0, contentsStart, contentsEnd, fileLength - contentsEnd]`. The two segments cover everything *except* the `/Contents` value itself.
5	**Read the signed bytes.** Concatenate `file[0 .. contentsStart-1]` and `file[contentsEnd .. fileLength-1]`. These are the exact bytes the signature covers — everything except the `/Contents` hex value. *Debug tip:* if you suspect byte range issues, dump these bytes to a file and hash them manually. Compare with the `message-digest` attribute in the CMS.
6	**Hash the signed bytes.** Compute SHA-256 (or SHA-384/512) over the concatenated byte ranges. This hash becomes the `message-digest` signed attribute in the CMS structure.
7–8	**Sign the hash.** The private key (RSA or ECDSA) signs the DER-encoded signed attributes (which include the hash). This may happen locally or via a remote HSM/signing service. In the remote case, only the hash leaves your system — the private key never does. More on remote signing in ???.
9	**Build the CMS `SignedData` structure.** Include: digest algorithm, signer certificate, certificate chain, signed attributes (content-type, message-digest, signing-certificate-v2), signature value. DER-encode the result.
10	**Write CMS bytes into `/Contents`.** Hex-encode the DER bytes and write them at the exact byte offset of the `/Contents` value in the file. Remaining space is left as `00` padding. No other bytes in the file are modified.

Step 10 is a **raw byte write** — not a PDF object update. The file is opened as a random-access binary stream, the cursor is positioned at the `/Contents` hex string's start offset, and the hex chars are overwritten in place. If the CMS blob is larger than the pre-allocated space, signing

fails. If even a single byte is written at the wrong offset, the signature is invalid and the PDF may be corrupted. This is why you don't implement PDF signing from scratch — you use PDFBox or a similar library that handles the byte-level bookkeeping for you.

1.1.6 Incremental Save: The Foundation of Multi-Signature

Every signature operation uses **incremental save** (ISO 32000-2:2020 §7.5.6). The original file bytes are never modified — new objects are appended after the existing `%%EOF`.

This is the mechanism that makes multiple independent signatures possible. Without incremental save, adding a second signature would modify the bytes covered by the first signature, invalidating it. With incremental save, the first signature's bytes remain untouched — the second signature's data is simply appended at the end.

Each signature's `/ByteRange` covers everything up to and including its own incremental update — but **not** the updates that come after:

- Signature 1's byte range: `[0, …, …, M]` — covers original + update #1
- Signature 2's byte range: `[0, …, …, P]` — covers original + update #1 + update #2

This is why Signature 1 remains valid after Signature 2 is added: Signature 2's bytes are **appended after** the range that Signature 1 covers. From Signature 1's perspective, those bytes are "trailing" — present in the file but outside the signed range.

"The file has been modified since signing" — don't panic.

This is the single most common false alarm in PDF signature validation. A validator detects trailing bytes after a signature's byte range and flags it as "modified." But in the vast majority of cases, those trailing bytes are simply a later incremental update — another signature, a form fill, or an annotation.

What to check:

1. Is the trailing data a valid incremental update? (Look for xref table + trailer + %%EOF.)
2. Does it correspond to an expected operation? (Another signature, a form field being filled.)
3. Did the byte range change? (The original signature's bytes at their original offsets should be byte-for-byte identical.)

If the answers are yes, yes, and no — the signature is fine. The "modification" is just the normal operation of PDF's append-only architecture.

When to actually worry:

- Trailing bytes that aren't a valid incremental update — raw data appended to the file
- An incremental update that modifies objects covered by an existing signature in unexpected ways (e.g., page content changes)
- Multiple %%EOF markers where the trailing section isn't a proper PDF update

1.1.7 Widget Annotations and Page Placement

Every signature field has an associated widget annotation (ISO 32000-2:2020 §12.5.6.19) that defines its visual presence on a page.

1.1.7.1 The `/Rect` Coordinate System

The widget's `/Rect` array specifies `[llx, lly, urx, ury]` in **default user space** coordinates:

PDF coordinates have **origin at lower-left** with Y increasing upward. This is the opposite of screen coordinates (origin top-left, Y increasing downward). This will bite you. It bites everyone. You will write the conversion wrong the first time. Here it is, so you can copy it:

```
// viewport = page.getViewport({ scale: scale })
var left = bbox[0] * scale;
var top  = viewport.height - (bbox[1] + bbox[3]) * scale;
var width = bbox[2] * scale;
var height = bbox[3] * scale;
```

- X translates directly (both coordinate systems have X increasing rightward)
- Y must be flipped: PDF Y=0 is bottom, screen Y=0 is top. Note the `bbox[1] + bbox[3]` — that's lower-left-Y plus height, giving the top edge in PDF space, which maps to the top edge in screen space.
- Width scales linearly
- Height scales linearly

Where `bbox` is `[lowerLeftX, lowerLeftY, width, height]` as extracted by PDFBox's `PDRectangle`. Note that PDFBox gives you `[x, y, width, height]` while the raw PDF `/Rect` is `[llx, lly, urx, ury]` — PDFBox does the conversion for you. Don't convert twice.

1.1.7.2 Invisible Signatures

A signature can be **invisible** — having no visual appearance on the page:

- **Zero-size rect:** `/Rect [0 0 0 0]` — the widget exists but has no area
- **No widget at all:** The field has no annotation entry (valid per spec, but some viewers complain)

Invisible signatures are common for:

- Certification signatures — the document author certifies the document without cluttering the layout
- Machine-generated signatures — automated workflows where nobody's looking at the PDF
- Counter-signatures — additional approval signatures in complex chains where visual space is limited

Should your signature be visible or invisible?

For approval signatures intended for human signers: make them visible. Users expect to *see* their signature on the page. A visible signature provides a visual anchor — "I signed here" — and helps in audit scenarios.

For certification signatures and automated workflows: invisible is usually fine. The certification status is shown in the viewer's signature panel, not on the page.

For machine-to-machine: always invisible. No human is looking at the page. Adding a visual appearance just wastes space and processing time.

One exception: if you're in a regulated industry where auditors review printed copies of signed PDFs (yes, this still happens in 2026), visible signatures are essential because auditors can't check digital signatures on paper. In that case, include the signer's name, the signing time, and ideally a note like "Digitally signed — verify electronically."

1.1.8 AcroForm `/SigFlags`: Document-Level Signature Metadata

> If the document contains signature fields, the AcroForm dictionary shall include a SigFlags entry.
>
> — ISO 32000-2:2020 §12.7.2, Table 225

Bit	Value	Name	Effect on Conforming Readers
1	1	`SignaturesExist`	At least one signature field has a value. Readers should present signature-specific UI (e.g., the blue bar at the top of Adobe Acrobat).
2	2	`AppendOnly`	The document **shall** only be saved incrementally. A conforming reader that allows editing **must not** do a full save — it must append. This is the single most important flag for signature preservation.

In practice, both bits should be set (`/SigFlags 3`) whenever the document contains any signed signature field. This was already discussed above, but it bears repeating: if you get this wrong, signatures will be destroyed by innocent save operations, and the blame will be on your tool.

1.1.9 PDFBox API Mapping

For those of you who skipped here — I don't blame you, this is the section with the code — here's how the spec concepts map to PDFBox 3.x classes:

PDF Concept	PDFBox Class	Key Methods
Signature field	`PDSignatureField`	`getSignature()`, `getWidgets()`, `getPartialName()`
Signature dictionary	`PDSignature`	`getByteRange()`, `getContents(byte[])`, `getSubFilter()`, `getName()`, `getSignDate()`

PDF Concept	PDFBox Class	Key Methods
AcroForm	`PDAcroForm`	`getFields()`, `getFieldTree()`, `setSignaturesExist()`, `setAppendOnly()`
Widget annotation	`PDAnnotationWidget`	`getRectangle()`, `getPage()`, `getNormalAppearanceStream()`
Appearance stream	`PDFormXObject`	`getStream()`, `getBBox()`, `getResources()`
Adding a signature	`PDDocument`	`addSignature(PDSignature, SignatureInterface, SignatureOptions)`
Incremental save	`PDDocument`	`saveIncremental(OutputStream)`

1.1.9.1 Minimal Signing Code (Key Lines)

The essential PDFBox signing code in ~20 lines. This is the skeleton — the full, production-ready version is in Appendix A, but these are the lines that matter:

```
PDDocument doc = Loader.loadPDF(pdfBytes);
PDAcroForm acroForm = doc.getDocumentCatalog().getAcroForm();

PDSignature signature = new PDSignature();
signature.setFilter(PDSignature.FILTER_ADOBE_PPKLITE);
signature.setSubFilter(PDSignature.SUBFILTER_ETSI_CADES_DETACHED);
signature.setName("John Doe");
signature.setSignDate(Calendar.getInstance());

SignatureOptions options = new SignatureOptions();
options.setPreferredSignatureSize(0x6000);
options.setVisualSignature(appearanceStream);

doc.addSignature(signature, signingInterface, options);
doc.saveIncremental(outputStream);
```

- Always load from bytes. Don't create a new `PDDocument()` and try to `saveIncremental()` — PDFBox 3.x will throw `IllegalStateException: document was not loaded from a file or a stream`. Yes, this error message has confused every single person who's ever encountered it.
- Filter is always `Adobe.PPKLite` for interoperability. Don't be creative here.
- SubFilter: use `ETSI.CAdES.detached` for PAdES compliance. See the earlier section for why.
- Pre-allocate 24KB for the CMS blob. **Not** the PDFBox default of 9KB. See the pre-allocation table above.
- Visual appearance — set this to `null` for invisible signatures. Or provide an `InputStream` of a pre-built appearance.
- Register the signature and the `SignatureInterface`. The interface's `sign()` method will

be called during `saveIncremental()`.
- **Incremental save.** There is no other option. Do not call `save()` on a document you're signing.

1.1.9.2 The `SignatureInterface`: Your Extension Point

```
public interface SignatureInterface {
    byte[] sign(InputStream content) throws IOException;
}
```

- Called by PDFBox during `saveIncremental()`. The `InputStream` provides the concatenated byte ranges — this is the data you need to hash and sign. Your implementation builds the CMS `SignedData` blob and returns the DER-encoded bytes.

This is the **only thing you need to implement**. PDFBox handles the PDF structure, the byte range calculation, the incremental save, the widget creation, the appearance stream embedding. You handle the cryptography.

Keep your `SignatureInterface` implementation stateless and testable.

Don't put PDF logic in there. Don't reference the `PDDocument`. Your `sign()` method receives an `InputStream` of bytes and returns CMS bytes. That's it. This makes it trivially testable — pass in any byte stream, check that the output is valid CMS. It also makes it easy to swap between local signing (BouncyCastle) and remote signing (HSM, cloud) without touching any PDF code.

1.1.10 Common Mistakes and How to Avoid Them

After years of working with PDF signatures, the same problems come up over and over. Here's the hit list:

#	Mistake	Fix
1	**Trusting `/Name` for signer identity.** Many systems display the `/Name` field from the signature dictionary as if it's the verified signer name. It's not. It's free-text set by whoever controls the signing process.	Always extract the signer's identity from the X.509 certificate in the CMS structure. Display the certificate's Subject CN (or the full Subject DN for enterprise contexts).
2	**Using `PDDocument.save()` instead of `saveIncremental()`.** Full save rewrites the entire file, destroying all existing signatures.	Always use `saveIncremental()`. Make it a code review checklist item: "Does this code path call `save()` on a signed document? Reject."
3	**Pre-allocating too little space for `/Contents`.** Works fine in testing with simple certificates, breaks in production when chains get longer or timestamps are added.	Use `0x6000` (24KB) minimum. For PAdES-B-LT, use `0x18000` (96KB). Test with your actual TSA and certificate chain, not with test certificates.

#	Mistake	Fix
4	**Forgetting `signing-certificate-v2` in the CMS attributes.** Technically valid as PKCS#7, but not PAdES-compliant and vulnerable to certificate substitution.	Use BouncyCastle's `JcaSignerInfoGeneratorBuilder` with the correct `DigestCalculatorProvider`. It adds the attribute automatically when configured correctly. See the code in Appendix A.
5	**Not including the certificate chain.** A signature with just the signer's certificate can't be validated by anyone who doesn't already have the issuer certificates.	Always include the full chain (signer + intermediates). You can omit the root CA — validators typically have their own trust stores. But include everything else.
6	**Creating a fresh `PDDocument` and calling `saveIncremental()`.** PDFBox 3.x requires the document to have been loaded from bytes.	Create a blank PDF, save it to bytes, load it back, then sign. See the test code in this chapter.
7	**Setting `/SigFlags` to 1 instead of 3.** Bit 1 alone means "signatures exist" but doesn't enforce append-only saving.	Always set `/SigFlags` to 3. No exceptions.
8	**Modifying the PDF between adding the signature and calling `saveIncremental()`.** Any change to the document graph between `addSignature()` and `saveIncremental()` may change byte offsets, breaking the signature.	Set up everything before calling `addSignature()`. Once you've added the signature, the very next call should be `saveIncremental()`. Nothing in between.

1.1.11 Key Points

- A PDF signature = signature field + signature dictionary + widget + appearance stream — all embedded in the document
- The signature dictionary's `/Contents` holds a CMS `SignedData` blob (hex-encoded, zero-padded)
- `/ByteRange` defines exactly which file bytes are signed — everything except `/Contents` itself
- `/SubFilter` determines the signature format: use `/ETSI.CAdES.detached` for PAdES compliance — there's no good reason not to
- The `signing-certificate-v2` attribute is what distinguishes CAdES from plain PKCS#7 — and what prevents certificate substitution attacks
- All signatures use incremental save — original bytes are never modified, ever
- `/SigFlags` must be set to 3 (SignaturesExist + AppendOnly) to protect existing signatures — getting this wrong destroys other people's signatures

- Seed value dictionaries (`/SV`) can constrain how a field is signed — use them in templates to prevent signer mistakes
- Widget `/Rect` uses PDF coordinates (origin lower-left, Y up) — you will get the conversion wrong the first time, and that's OK
- PDFBox's `SignatureInterface.sign(InputStream)` is the single extension point for all signing logic — keep it clean, stateless, and testable
- When in doubt, pre-allocate more space for `/Contents` — wasted bytes are cheap, failed signatures are expensive
- "The file has been modified since signing" is usually not a problem — it's usually just a later incremental update

1.1.12 Specification References

Chapter 2

Security, Incidents & Outlook

2.1 PDF Signature Attacks: A Complete Technical Analysis

> We found 21 out of 22 desktop viewer applications and 5 out of 7 online validation services to be vulnerable to at least one of our attacks.
>
> — Vladislav Mladenov et al. 1 Trillion Dollar Refund

For nearly two decades, the PDF signature ecosystem operated on an assumption that turned out to be wrong: that viewers actually verified what they claimed to verify. Between 2019 and 2021, a research team at Ruhr University Bochum systematically dismantled this assumption. They showed that an attacker could take a validly signed PDF, modify it in specific ways, and present the result to any major PDF viewer — Adobe Acrobat, Foxit Reader, Nitro, LibreOffice, Okular, dozens of others — and the viewer would display a green checkmark and the text ”Signature is valid.”

The signed content had been altered. The viewer said it hadn’t. Every viewer was wrong.

This chapter is a complete technical analysis of every major attack against PDF digital signatures — from the Bochum research program to earlier CVEs, from the theoretical mechanics to working code that demonstrates each attack class. The purpose is not to enable attacks but to make them impossible to misunderstand. If you build or maintain a PDF signature validation system, you need to understand exactly how these attacks work so that your code cannot be fooled by them. If you are a security researcher, this chapter gives you the foundation to find the next generation of PDF signature vulnerabilities — because the Bochum team found the obvious ones, but the attack surface is far from fully explored.

2.1.1 The Researchers

The PDF signature attacks of 2019–2021 were the work of the **Chair of Network and Data Security** (Lehrstuhl für Netz- und Datensicherheit) at Ruhr University Bochum, Germany, led by **Prof. Dr. Jörg Schwenk**.

The core research team:

- **Vladislav Mladenov** — PhD researcher, co-first author of the CCS 2019 paper, led the implementation and testing of the USF, ISA, and SWA attack variants
- **Christian Mainka** — post-doctoral researcher, co-first author of both the CCS 2019 and NDSS 2021 papers, designed the Shadow Attack taxonomy and coordinated responsible disclosure
- **Karsten Meyer zu Selhausen** — researcher and co-founder of **Hackmanit GmbH**, the security consultancy that spun out of the Bochum group; contributed to attack implementation and vendor coordination

- **Martin Grothe** — researcher, contributed to the CCS 2019 paper's systematic evaluation across 22 viewers
- **Simon Rohlmann** — researcher, co-author of the NDSS 2021 Shadow Attacks paper, developed the Hide-and-Replace variant
- **Prof. Dr. Jörg Schwenk** — senior author on both papers, provided the research direction and the formal security model for PDF signatures

The team maintained a coordinated disclosure website at **pdf-insecurity.org**, where they published proof-of-concept PDFs, detailed attack descriptions, and a viewer-by-viewer vulnerability matrix. Hackmanit GmbH later developed **PDF Detector**, a tool for checking PDFs against known attack patterns.

The two landmark papers:

1. *"1 Trillion Dollar Refund: How To Spoof PDF Signatures"* — presented at **ACM Conference on Computer and Communications Security (CCS)**, November 2019, London. This paper introduced three attack classes (USF, ISA, SWA) and tested them against 22 desktop viewers and 7 online validation services.
2. *"Shadow Attacks: Hiding and Replacing Content in Signed PDFs"* — presented at **Network and Distributed Systems Security Symposium (NDSS)**, February 2021 (virtual). This paper introduced a fundamentally different attack model where malicious content is prepared *before* the document is signed.

Both conferences are top-tier academic venues in computer security. The CCS 2019 paper won a **Distinguished Paper Award** — a recognition given to only a handful of papers at each conference.

2.1.2 Before Bochum: The State of PDF Signature Validation

To understand why the Bochum attacks worked, you need to understand what PDF viewers *were* doing when they claimed to "validate" a signature.

A correct signature validation must verify at least the following:

1. **Structural integrity**: The byte range specified in the `/ByteRange` array must cover the entire file except the gap reserved for the `/Contents` value. There must be no unaccounted bytes before, between, or after the byte ranges.
2. **Cryptographic verification**: The CMS `SignedData` structure in `/Contents` must contain a valid signature over the hash of the byte range data. The digest algorithm, signing algorithm, and signed attributes must all be consistent.
3. **Certificate chain validation**: The signer's certificate must chain to a trusted root. The chain must be valid at the time of signing (or at the time of a trusted timestamp). Revocation status must be checked.
4. **Modification detection**: If additional data has been appended to the file after the signature (an incremental update), the viewer must determine whether those changes are permissible under the signature's `/TransformMethod` (e.g., DocMDP permission level) or whether they indicate tampering.

What the Bochum team discovered was that most viewers implemented step 3 reasonably well (they checked certificate chains) but failed catastrophically at steps 1, 2, and 4. Some viewers didn't check the cryptographic signature value at all. Some didn't verify that the

byte range covered the entire file. Some allowed arbitrary changes after signing without any warning.

The result: a perfectly executed certificate chain validation was protecting… nothing. The viewers were carefully verifying *who* signed the document, while completely ignoring *whether the document had been changed since they signed it*.

2.1.3 Attack Class 1: Universal Signature Forgery (USF)

2.1.3.1 The Concept

Universal Signature Forgery is the simplest and most devastating of the three original attack classes. The premise is almost embarrassingly straightforward: what happens if the CMS signature value in `/Contents` is wrong?

A correct implementation should reject the signature immediately — if the cryptographic value doesn't verify, nothing else matters. What the Bochum team found was that some viewers never checked.

In the most extreme cases, the `/Contents` value could be empty (all zeros), filled with random bytes, or contain a valid CMS structure that signed completely different data — and the viewer would still display "Signature is valid" with a green checkmark.

2.1.3.2 How It Works

The attack requires no special tools and no knowledge of the signer's private key. The attacker takes a legitimately signed PDF, modifies the document content (changes text, replaces pages, adds content), and re-calculates any internal structures (cross-reference table, object offsets) needed to keep the file syntactically valid. The `/Contents` value — the CMS `SignedData` blob — is left unchanged, even though it now contains a signature over the *original* document bytes, not the modified ones.

In a correct implementation, the viewer would:

1. Read the `/ByteRange` to determine which bytes are signed
2. Hash those bytes using the digest algorithm specified in the CMS structure
3. Extract the signature value from the CMS `SignerInfo`
4. Verify the signature over the hash using the signer's public key
5. If verification fails reject the signature

Vulnerable viewers skipped step 4, step 3, or in some cases both. They parsed the CMS structure to extract the signer's certificate (for display purposes), checked that the certificate chained to a trust anchor, and then displayed the result — without ever verifying that the signature value was mathematically valid for the current document content.

2.1.3.3 The Variants

The Bochum team identified three USF variants with increasing severity:

USF Variant 1: Manipulated SignerInfo

The `SignerInfo.signature` value (the actual RSASSA-PKCS1-v1_5 or ECDSA bytes) is replaced with random data. A correct implementation rejects this immediately during RSA/ECDSA verification. Vulnerable viewers never reached that step.

USF Variant 2: Manipulated ContentInfo

The outer CMS `ContentInfo` wrapping is modified so the `SignedData` structure is structurally invalid — wrong OIDs, missing fields, or inconsistent version numbers. A correct implementation rejects this during CMS parsing. Vulnerable viewers used lenient parsing that silently ignored structural errors.

USF Variant 3: Manipulated `/Contents` Value

The entire `/Contents` hex string is replaced — either with zeros, with a truncated CMS structure, or with a CMS structure copied from a different document. This tests whether the viewer checks the relationship between the CMS content and the actual document bytes at all.

2.1.3.4 Demonstration: Detecting USF Vulnerability

The following code demonstrates how to detect whether a signed PDF's CMS signature actually validates cryptographically — the check that USF-vulnerable viewers failed to perform. This is the *defense*, not the attack: if you are building a validator, this is the minimum you must implement.

```
import org.apache.pdfbox.Loader;
import org.apache.pdfbox.pdmodel.PDDocument;
import org.apache.pdfbox.pdmodel.interactive.digitalsignature.PDSignature;
import org.bouncycastle.cert.X509CertificateHolder;
import org.bouncycastle.cert.jcajce.JcaX509CertificateConverter;
import org.bouncycastle.cms.CMSProcessableByteArray;
import org.bouncycastle.cms.CMSSignedData;
import org.bouncycastle.cms.SignerInformation;
import org.bouncycastle.cms.jcajce.JcaSimpleSignerInfoVerifierBuilder;
import org.bouncycastle.jce.provider.BouncyCastleProvider;
import org.bouncycastle.util.Store;

import java.io.FileInputStream;
import java.io.InputStream;
import java.security.Security;
import java.security.cert.X509Certificate;
import java.util.Collection;

/**
 * Demonstrates the cryptographic signature verification that USF-vulnerable
 * viewers failed to perform. This is the MINIMUM check for signature integrity.
 */
public class UsfDefenseCheck {

    static {
        Security.addProvider(new BouncyCastleProvider());
    }

    public static void verifySignature(byte[] pdfBytes) throws Exception {
        PDDocument doc = Loader.loadPDF(pdfBytes);
```

```
for (PDSignature sig : doc.getSignatureDictionaries()) {
    // Step 1: Extract the signed byte ranges
    byte[] signedContent = sig.getSignedContent(
            new ByteArrayInputStream(pdfBytes));

    // Step 2: Extract the CMS SignedData from /Contents
    byte[] cmsBytes = sig.getContents(
            new ByteArrayInputStream(pdfBytes));

    // Step 3: Parse the CMS structure
    CMSSignedData cmsSignedData = new CMSSignedData(
            new CMSProcessableByteArray(signedContent),
            cmsBytes);

    // Step 4: Verify each signer's cryptographic signature
    Store<X509CertificateHolder> certStore =
            cmsSignedData.getCertificates();

    for (SignerInformation signer :
            cmsSignedData.getSignerInfos().getSigners()) {

        Collection<X509CertificateHolder> matches =
                certStore.getMatches(signer.getSID());

        if (matches.isEmpty()) {
            System.err.println(
                    "FAIL: No certificate found for signer");
            continue;
        }

        X509CertificateHolder certHolder = matches.iterator().next();
        X509Certificate cert = new JcaX509CertificateConverter()
                .setProvider("BC")
                .getCertificate(certHolder);

        // THIS IS THE CHECK THAT USF-VULNERABLE VIEWERS SKIPPED
        boolean cryptoValid = signer.verify(
                new JcaSimpleSignerInfoVerifierBuilder()
                        .setProvider("BC")
                        .build(cert));

        if (!cryptoValid) {
            System.err.println(
                    "FAIL: Cryptographic signature verification "
                    + "FAILED for signer: " + cert.getSubjectX500Principal());
            System.err.println(
                    "This document may have been tampered with (USF attack)");
        } else {
            System.out.println(
                    "PASS: Cryptographic signature valid for: "
                    + cert.getSubjectX500Principal());
        }
    }
}
```

```
        doc.close();
    }
}
```

- Extracts the bytes covered by `/ByteRange` — this is the data that was supposedly signed
- Extracts the raw CMS `SignedData` blob from the `/Contents` hex string
- Creates a CMS structure with the signed content as the detached data — BouncyCastle will use this for digest comparison
- If no certificate matches the `SignerInfo.sid`, the CMS structure is malformed — reject immediately
- **This is the critical line.** `signer.verify()` performs the actual RSA/ECDSA verification: it computes the digest over the signed content, verifies the signed attributes, and checks the signature value against the signer's public key. USF-vulnerable viewers never called the equivalent of this method.

If your signature validation code does not include a step equivalent to `signer.verify()` — an actual cryptographic verification of the signature value against the document bytes — your code is vulnerable to Universal Signature Forgery. This is non-negotiable. It must happen before you display any "valid" indicator to the user.

2.1.3.5 Constructing a USF Attack (Proof of Concept)

To understand USF fully, here is how an attacker constructs one. This is *not* production exploit code — it is a minimal demonstration of the mechanics that every PDF signature validator must defend against.

```
import org.apache.pdfbox.Loader;
import org.apache.pdfbox.pdmodel.PDDocument;
import org.apache.pdfbox.pdmodel.PDPage;
import org.apache.pdfbox.pdmodel.PDPageContentStream;
import org.apache.pdfbox.pdmodel.font.PDType1Font;
import org.apache.pdfbox.pdmodel.font.Standard14Fonts;

import java.io.ByteArrayOutputStream;
import java.io.File;
import java.nio.file.Files;

/**
 * Demonstrates USF attack mechanics. Takes a signed PDF, modifies the visible
 * content, and writes the result. The CMS signature value is left unchanged --
 * it now signs the ORIGINAL content, not the modified content.
 *
 * A correct validator will reject this because the digest over the byte range
 * no longer matches the digest in the CMS SignerInfo.
 * A USF-vulnerable validator will show "Signature is valid."
 */
public class UsfAttackDemo {

    public static void main(String[] args) throws Exception {
        byte[] originalPdf = Files.readAllBytes(
                new File("signed-document.pdf").toPath());
```

```
        // Load the signed PDF
        PDDocument doc = Loader.loadPDF(originalPdf);

        // Add a new page with attacker-controlled content
        PDPage attackPage = new PDPage();
        doc.addPage(attackPage);

        PDPageContentStream cs = new PDPageContentStream(doc, attackPage);
        cs.beginText();
        cs.setFont(
                new PDType1Font(Standard14Fonts.FontName.HELVETICA_BOLD), 24);
        cs.newLineAtOffset(50, 700);
        cs.showText("APPROVED - Payment of $1,000,000 authorized");
        cs.endText();
        cs.close();

        // Save with full rewrite — this changes object offsets,
        // xref table, and file length. The /ByteRange in the original
        // signature now covers different bytes, but the /Contents
        // CMS value still contains the hash of the ORIGINAL bytes.
        ByteArrayOutputStream baos = new ByteArrayOutputStream();
        doc.save(baos);
        doc.close();

        Files.write(
                new File("usf-attack-result.pdf").toPath(), baos.toByteArray());

        // A correct validator: REJECTS (digest mismatch)
        // A USF-vulnerable validator: shows green checkmark
    }
}
```

- Modifying the document structure after it was signed — adding a page, changing text, anything
- The attacker can insert any content they want
- A full `save()` (not `saveIncremental()`) rewrites the entire file, changing byte offsets everywhere. The original `/ByteRange` and `/Contents` are preserved structurally, but the bytes they reference have changed. The CMS signature now signs data that no longer exists at those byte positions.

This code produces a PDF that any *correct* validator will reject. The point is that in 2019, most validators were not correct. The digest computed over the new byte range content will not match the digest inside the CMS `SignerInfo.digestAlgorithm` — the very first check in proper CMS verification detects this. USF worked because viewers displayed the signer's certificate information *without performing this check*.

2.1.4 Attack Class 2: Incremental Saving Attack (ISA)

2.1.4.1 The Concept

The Incremental Saving Attack is more subtle than USF and exploits a feature that is fundamental to how PDF signatures work: **incremental updates**.

When a PDF is signed, the signing process:

1. Appends the signature dictionary and any new objects to the end of the file
2. Appends a new cross-reference section pointing to the new/modified objects
3. Appends a new trailer
4. The `/ByteRange` in the signature covers everything from the beginning of the file through the end of this new revision — with a gap for the `/Contents` value

The critical insight is that PDF is designed to allow *additional* incremental updates after signing. This is intentional — you need to be able to add a second signature to an already-signed document, or fill in form fields on a signed form. ISO 32000-2:2020 §12.8.1 explicitly allows certain modifications after signing, depending on the signature's `/TransformMethod` and permission level.

The question is: does the viewer correctly distinguish between *permissible* incremental updates (adding another signature) and *impermissible* ones (changing the page content)?

The Bochum team found that most viewers did not.

2.1.4.2 How It Works

The attacker takes a legitimately signed PDF and appends a new incremental update — exactly the way PDFBox's `saveIncremental()` method does. But instead of adding a second signature or filling in a form field, the attacker appends objects that change the visible content: modified page content streams, replaced images, rewritten text, or entirely new pages.

The original signature remains intact — its byte range still covers the original revision, and its CMS signature is still mathematically valid over those bytes. The appended revision contains the modifications, complete with a new cross-reference section and trailer that redirect the viewer to the modified objects.

A correct validator must:

1. Verify the signature is cryptographically valid (steps from USF defense)
2. Determine the document's revision at the time of signing (the byte range endpoint)
3. Compare the current document state to the signed revision
4. If there are changes beyond the signed revision, evaluate whether those changes are permissible under the signature's DocMDP permissions
5. If impermissible changes are detected, display a clear warning: "The document has been modified after signing"

Vulnerable viewers either:

- Did not compare the current document state to the signed revision at all
- Compared but accepted all incremental updates as permissible
- Only checked whether the appended data was "syntactically valid PDF" rather than whether it changed the visible content

2.1.4.3 The Variants

ISA Variant 1: Content Replacement via Incremental Update

The attacker appends a new revision that redefines existing page content stream objects. The cross-reference in the new revision points to new objects at the end of the file that replace the original content. The viewer renders the new content; the signature covers the old content.

ISA Variant 2: Page Insertion/Deletion

The attacker appends a new revision that modifies the page tree — adding new pages, removing existing pages, or reordering them. The `/Pages` dictionary in the new revision points to a different set of page objects.

ISA Variant 3: Annotation and Form Field Manipulation

The attacker appends annotations or modifies form field values. This variant is particularly insidious because some annotation changes *are* legitimately allowed after signing (e.g., adding signature fields for subsequent signers). The boundary between ”allowed” and ”not allowed” is defined by the DocMDP permission level, and most viewers did not enforce it correctly.

2.1.4.4 Demonstration: ISA Attack Mechanics

```
import org.apache.pdfbox.Loader;
import org.apache.pdfbox.cos.COSDictionary;
import org.apache.pdfbox.cos.COSName;
import org.apache.pdfbox.cos.COSArray;
import org.apache.pdfbox.pdmodel.PDDocument;
import org.apache.pdfbox.pdmodel.PDPage;
import org.apache.pdfbox.pdmodel.PDPageContentStream;
import org.apache.pdfbox.pdmodel.common.PDRectangle;
import org.apache.pdfbox.pdmodel.font.PDType1Font;
import org.apache.pdfbox.pdmodel.font.Standard14Fonts;

import java.io.ByteArrayOutputStream;
import java.io.File;
import java.nio.file.Files;

/**
 * Demonstrates ISA mechanics. Takes a signed PDF and appends an incremental
 * update that replaces the visible content of page 1.
 *
 * The original signature remains cryptographically valid over the original
 * byte range. The appended revision changes what the user sees.
 *
 * A correct validator detects the impermissible modification.
 * An ISA-vulnerable validator shows "Signature is valid" on the modified content.
 */
public class IsaAttackDemo {

    public static void main(String[] args) throws Exception {
        byte[] signedPdf = Files.readAllBytes(
                new File("signed-document.pdf").toPath());

        // Load for incremental save — preserves the original bytes
        PDDocument doc = Loader.loadPDF(signedPdf);

        // Get the first page and replace its content
```

```
        PDPage page = doc.getPage(0);

        // Create a new content stream that overwrites existing content
        PDPageContentStream cs = new PDPageContentStream(
                doc, page,
                PDPageContentStream.AppendMode.OVERWRITE,
                true);

        cs.beginText();
        cs.setFont(
                new PDType1Font(Standard14Fonts.FontName.HELVETICA_BOLD), 36);
        cs.newLineAtOffset(50, 700);
        cs.showText("CONTRACT VOIDED");
        cs.endText();
        cs.close();

        // Save incrementally — appends new objects + xref + trailer
        // The original signature's byte range is UNTOUCHED
        ByteArrayOutputStream baos = new ByteArrayOutputStream();
        doc.saveIncremental(baos);
        doc.close();

        Files.write(
                new File("isa-attack-result.pdf").toPath(), baos.toByteArray());

        // The file now looks like this:
        // [original PDF bytes ... signature ... %%EOF]  <-- signed revision
        // [new objects ... new xref ... new trailer ... %%EOF]  <-- attacker's appendage
        //
        // The signature covers only the first section.
        // The viewer renders the second section.
        // A correct validator: warns "Document modified after signing"
        // An ISA-vulnerable validator: shows green checkmark
    }
}
```

- `AppendMode.OVERWRITE` replaces the existing content stream. PDFBox tracks this as a modified object, which will be written in the incremental update
- The attacker-controlled content — can be anything
- `saveIncremental()` appends to the existing file bytes without modifying them. The original signature's `/ByteRange` and `/Contents` remain at their original byte positions. The new revision simply adds new objects and a new cross-reference section after the original `%%EOF`

2.1.4.5 Detecting ISA: Revision Comparison

The defense against ISA requires comparing the document as rendered from the signed revision to the document as rendered from the current (potentially modified) revision.

```
import org.apache.pdfbox.Loader;
import org.apache.pdfbox.pdmodel.PDDocument;
import org.apache.pdfbox.pdmodel.interactive.digitalsignature.PDSignature;

import java.io.ByteArrayInputStream;
```

```
import java.util.Arrays;

/**
 * Demonstrates how to extract the signed revision of a PDF and compare it
 * to the full file — the core defense against ISA.
 */
public class IsaDefenseCheck {

    public static void checkForAppendedContent(byte[] pdfBytes)
            throws Exception {

        PDDocument doc = Loader.loadPDF(pdfBytes);

        for (PDSignature sig : doc.getSignatureDictionaries()) {
            int[] byteRange = sig.getByteRange();

            if (byteRange == null || byteRange.length != 4) {
                System.err.println("FAIL: Invalid or missing /ByteRange");
                continue;
            }

            // The signed region ends at byteRange[2] + byteRange[3]
            int signedEnd = byteRange[2] + byteRange[3];

            // Check: does the file extend beyond the signed region?
            if (pdfBytes.length > signedEnd) {
                int extraBytes = pdfBytes.length - signedEnd;
                System.err.println(
                        "WARNING: File contains " + extraBytes
                        + " bytes AFTER the signed byte range");
                System.err.println(
                        "This indicates an incremental update after signing.");
                System.err.println(
                        "These bytes are NOT covered by the signature.");
                System.err.println(
                        "Investigate whether the changes are permissible "
                        + "(e.g., additional signatures, form fills) "
                        + "or malicious (content replacement).");

                // Extract the signed revision for comparison
                byte[] signedRevision = Arrays.copyOfRange(
                        pdfBytes, 0, signedEnd);

                // You can now load signedRevision as a separate PDDocument
                // and compare its rendered pages to the full document
                // to determine exactly what changed
            } else if (pdfBytes.length == signedEnd) {
                System.out.println(
                        "PASS: File ends exactly at the signed byte range. "
                        + "No incremental updates after signing.");
            } else {
                System.err.println(
                        "FAIL: File is SHORTER than the signed byte range. "
                        + "File is truncated or corrupted.");
            }
```

```
        }

        doc.close();
    }
}
```

- `/ByteRange` is an array of four integers: `[offset1, length1, offset2, length2]`. The two ranges cover everything before and after the `/Contents` gap
- The signed content ends at the start of range 2 plus its length — this is the last byte the signature covers
- If the file extends beyond this point, there is appended content that the signature does not cover. This is the ISA detection point
- Extracting the signed revision as a standalone PDF allows you to render it separately and compare to the current document state

A naive "does the file extend beyond the byte range?" check catches obvious ISA attacks, but it is not sufficient. A legitimate second signature also extends the file. The real check requires parsing the appended incremental update and determining *what* changed — was it another signature (allowed), a form fill (allowed under DocMDP P=3), or a content modification (never allowed)? This is the hard part of ISA defense, and it is where most viewers failed in 2019.

2.1.5 Attack Class 3: Signature Wrapping Attack (SWA)

2.1.5.1 The Concept

The Signature Wrapping Attack is the most technically sophisticated of the three original attack classes. Where USF exploits missing cryptographic verification and ISA exploits missing modification detection, SWA exploits the way viewers *locate* the signature within the file.

The core insight: the `/ByteRange` array tells the viewer which bytes are signed, but *nothing prevents an attacker from moving the signed bytes to a different location in the file* — as long as the byte values at the `/ByteRange` offsets still produce the same hash.

Actually, SWA is even simpler than that. The attacker doesn't need the same hash. The attacker modifies the `/ByteRange` array itself to point to a *different* region of the file — one that contains attacker-controlled content — while keeping the original CMS signature that was computed over the original content.

Wait — if the `/ByteRange` is modified, wouldn't the signature be invalid? Yes, *if the viewer reads the `/ByteRange` from the signed revision*. But many viewers read the `/ByteRange` from the *current* cross-reference table, which may have been modified by an incremental update. The attacker appends a new revision that:

1. Redefines the signature dictionary object to point to a new `/ByteRange`
2. Places attacker-controlled content at the byte positions specified by the new `/ByteRange`
3. Ensures the CMS signature (in the original `/Contents`) is structurally present

The viewer follows the new cross-reference to the redefined signature dictionary, reads the attacker's `/ByteRange`, hashes the attacker's content, and — if it doesn't actually verify the hash against the CMS signature (shades of USF) — displays "valid."

In some variants, the viewer *does* check the hash, but the attacker has been clever about which bytes are at the new `/ByteRange` positions, potentially including a copy of the original signed content or exploiting hash-algorithm weaknesses.

2.1.5.2 How It Works

```
Original file layout:
  [header ... objects ... page content ... ]
  [signature dict: /ByteRange [0 840 3000 1200] /Contents <CMS...>]
  [xref ... trailer ... %%EOF]

  Bytes 0-839 and 3000-4199 are signed.
  Bytes 840-2999 are the /Contents gap (CMS signature value).
  The CMS signature is valid over hash(bytes[0..839] + bytes[3000..4199]).

Attacker appends an incremental update:
  [... %%EOF]                              <-- original file ends here
  [new object: modified signature dict     <-- attacker redefines the sig dict
      /ByteRange [0 840 5000 1200]         <-- points to NEW byte positions
      /Contents <original CMS bytes>]      <-- keeps the original CMS value
  [attacker content at byte offset 5000]   <-- whatever the attacker wants
  [new xref pointing to new sig dict]
  [new trailer ... %%EOF]
```

The viewer follows the new xref, finds the redefined signature dictionary, reads `/ByteRange [0 840 5000 1200]`, and hashes bytes at those positions. If it checks the CMS signature against this hash, it will fail (because the CMS signed the *original* byte range content). But if the viewer is also vulnerable to USF (skips the hash verification), the attack succeeds.

SWA is often combined with elements of ISA and USF. The Bochum team found that many real-world exploits used a combination of attack techniques.

2.1.5.3 Demonstration: Detecting SWA

```
import org.apache.pdfbox.Loader;
import org.apache.pdfbox.pdmodel.PDDocument;
import org.apache.pdfbox.pdmodel.interactive.digitalsignature.PDSignature;

/**
 * Demonstrates SWA detection: verify that the /ByteRange covers the entire
 * file without gaps (except the /Contents gap) and without overlaps.
 */
public class SwaDefenseCheck {

    public static void checkByteRangeIntegrity(byte[] pdfBytes)
            throws Exception {

        PDDocument doc = Loader.loadPDF(pdfBytes);

        for (PDSignature sig : doc.getSignatureDictionaries()) {
            int[] byteRange = sig.getByteRange();
```

```
if (byteRange == null || byteRange.length != 4) {
    System.err.println("FAIL: Missing or malformed /ByteRange");
    continue;
}

int offset1 = byteRange[0]; // Should be 0
int length1 = byteRange[1];
int offset2 = byteRange[2];
int length2 = byteRange[3];
int signedEnd = offset2 + length2;

// Check 1: First range must start at byte 0
if (offset1 != 0) {
    System.err.println(
            "FAIL: /ByteRange does not start at byte 0. "
            + "Starts at: " + offset1);
}

// Check 2: The gap between ranges is the /Contents value
int gapStart = offset1 + length1;
int gapEnd = offset2;
int gapSize = gapEnd - gapStart;

if (gapSize <= 0) {
    System.err.println(
            "FAIL: /ByteRange gap is zero or negative. "
            + "Possible SWA indicator");
}

// Check 3: Verify /Contents hex string is at the gap position
// The gap should contain exactly the hex-encoded CMS signature
// surrounded by angle brackets: <hex...>
if (pdfBytes[gapStart] != '<') {
    System.err.println(
            "FAIL: Expected '<' at gap start (offset "
            + gapStart + "), found: 0x"
            + Integer.toHexString(
                    pdfBytes[gapStart] & 0xFF));
}

// Check 4: The signed region should cover the entire file
// (for a single-signature document with no subsequent updates)
if (signedEnd < pdfBytes.length) {
    System.err.println(
            "WARNING: /ByteRange ends at byte " + signedEnd
            + " but file is " + pdfBytes.length
            + " bytes. Unsigned trailing content detected");
}

// Check 5: Cross-validate that the /ByteRange in the file
// matches what we'd expect from the signed revision
// This requires parsing the original revision's xref
System.out.println(
        "ByteRange analysis: "
        + "range1=[" + offset1 + "," + (offset1 + length1) + ") "
```

```
                        + "gap=[" + gapStart + "," + gapEnd + ") "
                        + "range2=[" + offset2 + "," + signedEnd + ") "
                        + "fileSize=" + pdfBytes.length);
            }

            doc.close();
        }
    }
```

- The first byte range must start at offset 0. If it doesn't, there are unsigned bytes at the beginning of the file — a clear SWA indicator
- The gap between the two ranges must be positive and should correspond to the `/Contents` hex string. A zero or negative gap indicates structural manipulation
- The gap should contain the hex-encoded CMS value. Checking that it starts with < and ends with > is a basic sanity check

SWA defense requires more than just checking `/ByteRange` arithmetic. A sophisticated attacker can construct a valid-looking byte range that passes arithmetic checks but points to carefully crafted content. The complete defense is: (a) verify `/ByteRange` covers the file correctly, (b) verify the CMS signature cryptographically (USF defense), and (c) verify that the `/ByteRange` values come from the signed revision's cross-reference, not from an appended revision.

2.1.6 Attack Class 4: Shadow Attacks (2021)

2.1.6.1 A Fundamentally Different Threat Model

The three attacks from CCS 2019 (USF, ISA, SWA) all shared a common assumption: the attacker modifies a PDF *after* it has been legitimately signed. The signed document is genuine; the attacker's manipulation comes afterward.

Shadow Attacks, published at NDSS 2021, inverted the model. The attacker prepares the PDF *before* it is signed, embedding hidden malicious content that the signer cannot see during the signing process. The signer reviews the document, sees nothing suspicious, and signs it. The signed PDF is then sent to the recipient, who opens it — and sees different content from what the signer saw.

The signature is cryptographically valid. The signer genuinely signed those exact bytes. The bytes just don't mean what the signer thought they meant.

This is not a cryptographic failure. It is a semantic failure: the gap between what a human *sees* when they review a document and what the *bytes* actually encode. And it is far harder to defend against than USF, ISA, or SWA.

2.1.6.2 Shadow Attack Variant 1: Hide

The attacker creates a PDF with two layers of content — one visible, one hidden. The hidden content is placed *behind* the visible content using PDF features like:

- **Overlapping objects**: A white rectangle drawn on top of text, hiding it. The text is in the content stream; the rectangle covers it. After signing, the attacker removes the rectangle via an incremental update, revealing the hidden text.

- **Optional Content Groups (OCG)**: PDF's layer mechanism. Content can be tagged with `/OC` (Optional Content) markers and made visible or invisible via the `/OCProperties` dictionary. The attacker sets a layer to invisible before signing, then sets it to visible after signing.
- **Referenced XObjects**: Content referenced as `Form XObject` but not actually rendered on any page. After signing, an incremental update adds the XObject to a page's content stream.

The key constraint: *all of the hidden content must be present in the file at the time of signing*, so that it falls within the signed byte range. The attacker only changes the *visibility* via an incremental update after signing — which some viewers allowed without warning.

2.1.6.3 Shadow Attack Variant 2: Replace

The attacker creates a PDF where the visible content can be *replaced* by different visible content without modifying any objects in the signed byte range. This exploits **interactive form features**:

- A text field with a default value ("Contract for $1,000") and a different actual value ("Contract for $1,000,000") — the default is displayed initially, but changing which value is rendered requires only an annotation flag change
- Font references that can be swapped — the same Unicode code points render as different glyphs depending on which font is active
- Images referenced by name from a page's Resources dictionary — changing which image a name resolves to requires only modifying the Resources dictionary

The Replace variant is particularly dangerous because it exploits features that are *designed* to change document appearance (form filling, annotation updates) — the viewer must distinguish between a legitimate form fill and an attacker swapping content.

2.1.6.4 Shadow Attack Variant 3: Hide-and-Replace

The most powerful variant combines both techniques. The attacker creates a PDF that:

1. Contains the content the signer will see (layer A)
2. Contains the content the recipient will see (layer B), hidden behind layer A
3. Is structured so that a single incremental update (changing a few bytes in an annotation dictionary or OCG configuration) switches from layer A to layer B

After signing, the attacker appends the minimal incremental update needed to switch layers. If the viewer allows annotation or OCG changes after signing (as many did, because these are often considered "permissible" changes), the attack succeeds.

2.1.6.5 Demonstration: Shadow Attack (Hide Variant) Preparation

```
import org.apache.pdfbox.Loader;
import org.apache.pdfbox.pdmodel.PDDocument;
import org.apache.pdfbox.pdmodel.PDPage;
import org.apache.pdfbox.pdmodel.PDPageContentStream;
import org.apache.pdfbox.pdmodel.common.PDRectangle;
import org.apache.pdfbox.pdmodel.font.PDType1Font;
```

```
import org.apache.pdfbox.pdmodel.font.Standard14Fonts;

import java.io.ByteArrayOutputStream;
import java.io.File;
import java.nio.file.Files;

/**
 * Demonstrates the preparation phase of a Shadow Attack (Hide variant).
 * The attacker creates a PDF with hidden text behind a white overlay.
 *
 * BEFORE signing: Signer sees "Payment: $1,000"
 * AFTER signing + reveal: Recipient sees "Payment: $1,000,000"
 *
 * The hidden text ("Payment: $1,000,000") is present in the signed bytes.
 * The overlay (white rectangle) hides it. An incremental update that removes
 * the overlay reveals the hidden text — and the signature remains valid.
 */
public class ShadowAttackHideDemo {

    public static void main(String[] args) throws Exception {
        PDDocument doc = new PDDocument();
        PDPage page = new PDPage(PDRectangle.A4);
        doc.addPage(page);

        PDType1Font font = new PDType1Font(
                Standard14Fonts.FontName.HELVETICA);
        PDType1Font fontBold = new PDType1Font(
                Standard14Fonts.FontName.HELVETICA_BOLD);

        PDPageContentStream cs = new PDPageContentStream(doc, page);

        // Layer 1: The hidden content (written FIRST, so it's behind)
        // This text will be present in the signed bytes
        cs.beginText();
        cs.setFont(fontBold, 16);
        cs.newLineAtOffset(50, 700);
        cs.showText("Payment: $1,000,000");
        cs.endText();

        // Layer 2: The overlay that hides it
        // A white rectangle drawn ON TOP of the hidden text
        cs.setNonStrokingColor(1.0f, 1.0f, 1.0f); // White
        cs.addRect(45, 695, 250, 25); // Covers the text above
        cs.fill();

        // Layer 3: The visible content (what the signer sees)
        cs.setNonStrokingColor(0.0f, 0.0f, 0.0f); // Black
        cs.beginText();
        cs.setFont(fontBold, 16);
        cs.newLineAtOffset(50, 700);
        cs.showText("Payment: $1,000");
        cs.endText();

        // Legitimate-looking document body
        cs.beginText();
```

```
        cs.setFont(font, 12);
        cs.newLineAtOffset(50, 650);
        cs.showText("This agreement confirms the payment amount above.");
        cs.endText();

        cs.close();

        // Save — this PDF is now ready to be sent to the signer
        ByteArrayOutputStream baos = new ByteArrayOutputStream();
        doc.save(baos);
        doc.close();

        Files.write(
                new File("shadow-prepared.pdf").toPath(), baos.toByteArray());

        // The signer opens this PDF, sees "Payment: $1,000", and signs it.
        // The signed byte range includes ALL content: both the hidden
        // "$1,000,000" text and the white rectangle that covers it.
        //
        // After signing, the attacker creates an incremental update that
        // removes or makes transparent the white rectangle, revealing
        // "Payment: $1,000,000" — and the signature validates.
    }
}
```

- The hidden text is written to the content stream first. In PDF rendering order, later operators paint *over* earlier ones on the same area
- A white filled rectangle covers the hidden text completely. The signer sees only white space at this position
- The visible text is drawn on top of the white rectangle. This is what the signer reads when reviewing the document before signing

Shadow Attacks are fundamentally harder to prevent than USF, ISA, or SWA because the malicious content is *part of the signed data.* The signature is cryptographically valid over the exact bytes the signer intended to sign. The defense must go beyond byte-level verification into *semantic* analysis: does the document contain hidden content? Are there overlapping objects? Are there unused Form XObjects? Are there Optional Content Groups with suspicious visibility settings? This is an open research problem with no complete solution.

2.1.6.6 The Scope of Shadow Attack Vulnerability

The Bochum team tested 29 PDF viewers against the Shadow Attack variants. The results were comprehensive:

Table 2.1: Shadow Attack test results across PDF viewers (NDSS 2021)

Viewer	Hide	Replace	Hide-and-Replace
Adobe Acrobat Reader DC	Vulnerable	Vulnerable	Vulnerable
Foxit Reader	Vulnerable	Vulnerable	Vulnerable

Viewer	Hide	Replace	Hide-and-Replace
LibreOffice Draw	Vulnerable	Partially vulnerable	Vulnerable
Nitro Pro	Vulnerable	Vulnerable	Vulnerable
PDF-XChange	Vulnerable	Not vulnerable	Vulnerable
Okular	Vulnerable	Vulnerable	Vulnerable
Evince	Vulnerable	Vulnerable	Vulnerable
Chrome PDF Viewer	No signature validation	—	—
macOS Preview	Vulnerable	Vulnerable	Vulnerable

This table is a representative subset. The full results covering 29 viewers are available in the NDSS 2021 paper and at pdf-insecurity.org. Chrome's built-in PDF viewer does not validate signatures at all (it displays them but does not indicate validity), so Shadow Attacks are not applicable in the traditional sense — but the user also receives no warning that the document has been signed and potentially tampered with.

2.1.7 Pre-Bochum Vulnerabilities: Earlier PDF Signature Issues

The Bochum research was the most systematic analysis of PDF signature security, but it was not the first time vulnerabilities were discovered. Several earlier issues laid the groundwork — and reveal that the *category* of bug (failing to verify what you claim to verify) has been a persistent pattern in PDF signature implementations.

2.1.7.1 CVE-2018-16042 — Adobe Acrobat Signature Bypass (2018)

In 2018, Adobe patched **CVE-2018-16042** in Acrobat DC and Acrobat Reader DC (versions before 2019.008.20081). The vulnerability allowed a crafted PDF to display a valid signature indicator even when the document had been modified.

The technical details were not fully disclosed (Adobe's advisory was characteristically brief), but the vulnerability class — signature validation bypass via document manipulation — is the same category as the ISA attacks that Bochum would systematize a year later. This CVE was one of several signals that the PDF signature validation code in major viewers had not been subject to rigorous adversarial testing.

Affected versions: Acrobat DC/Reader DC before 2019.008.20081
Impact: Signature validation bypass — modified documents displayed as validly signed
Fix: Updated signature validation logic in the January 2019 security update

2.1.7.2 CVE-2018-4993 — Adobe Acrobat NTLM Credential Theft (2018)

While not strictly a signature bypass, **CVE-2018-4993** demonstrated a related risk: a crafted PDF could trigger NTLM authentication requests to an attacker-controlled server when

opened in Adobe Acrobat. Combined with a forged signature (via any of the bypass techniques), this creates a compound attack: the victim opens a ”validly signed” PDF, and their Windows credentials are silently exfiltrated.

Affected versions: Acrobat DC/Reader DC before 2018.011.20040
Impact: NTLM hash theft via SMB relay when opening a crafted PDF
Fix: Restricted external resource loading in the May 2018 security update

2.1.7.3 SHAttered and the SHA-1 Deprecation (2017)

In February 2017, researchers from Google and CWI Amsterdam published **SHAttered** — the first practical collision attack against SHA-1. They produced two different PDF documents with the same SHA-1 hash, proving that SHA-1 could no longer be relied upon for collision resistance.

For PDF signatures, this had immediate implications. The `adbe.pkcs7.sha1` SubFilter — which embeds a SHA-1 hash of the entire document as the CMS content data — was now theoretically vulnerable to a collision attack: an attacker could prepare two documents with the same SHA-1 hash, have the victim sign one, and then substitute the other.

The practical impact was limited (the collision required approximately 2^{63} computations and the two colliding documents had to be carefully constructed), but the theoretical break was sufficient to trigger industry-wide deprecation:

- ISO 32000-2:2020 deprecated `adbe.pkcs7.sha1` entirely
- Adobe Acrobat began showing warnings for SHA-1 signed documents
- The CA/Browser Forum required SHA-256 as the minimum for all new certificates
- PAdES profiles already mandated SHA-256 as the minimum digest algorithm

Table 2.2: SHA-1 timeline for PDF signatures

Year	Event
2005	Theoretical weakness in SHA-1 published (Wang et al.)
2011	NIST deprecated SHA-1 for digital signatures in federal use
2013	Microsoft announced SHA-1 certificate sunset for 2016
2017	SHAttered: first practical SHA-1 collision (Google/CWI). Two PDFs with identical SHA-1 hashes publicly demonstrated
2017	ISO 32000-2 deprecated `adbe.pkcs7.sha1` SubFilter
2020	SHA-1 collisions reduced to 2^{63} operations (Leurent and Peyrin, ”SHA-1 is a Shambles”), making chosen-prefix collisions feasible

If your code still generates signatures using SHA-1 (either via `adbe.pkcs7.sha1` or using SHA-1 as the `digestAlgorithm` in the CMS `SignerInfo`), stop immediately. SHA-1 is broken. Use SHA-256 or SHA-384. There is no legitimate reason to use SHA-1 for any new signature created after 2017.

2.1.7.4 The Comodo Registration Authority Breach (2011)

In March 2011 — the same month as DigiNotar, though discovered slightly earlier — an attacker compromised a **registration authority (RA)** affiliated with Comodo, one of the world's largest certificate authorities at the time.

The attacker used the compromised RA account to issue nine fraudulent SSL certificates for high-profile domains: `login.live.com`, `mail.google.com`, `www.google.com`, `login.yahoo.com`, `login.skype.com`, `addons.mozilla.org`, and three others. The certificates were issued by Comodo's legitimate intermediate CA, meaning they chained correctly to a trusted root.

The breach was discovered quickly because the attacker tested one of the certificates against a live server, and certificate pinning in Google Chrome detected the mismatch. Without Chrome's certificate pinning, the fraudulent certificates could have been used for undetectable man-in-the-middle attacks.

For PDF signatures: The Comodo breach demonstrated that even without compromising a root CA's private key, an attacker could obtain legitimate-looking certificates through a *registration authority* compromise — a weaker link in the chain. A document signed with one of these fraudulent certificates would have validated correctly in any PDF viewer that trusted Comodo's root. The signer would appear to be "Google" or "Microsoft" or "Yahoo" — entities that obviously did not sign the document.

The incident led to:

- Mandatory two-factor authentication for all RA accounts at major CAs
- Domain control validation (DCV) requirements tightened by the CA/Browser Forum
- Increased scrutiny of the RA model, eventually leading several CAs to eliminate external RAs entirely

2.1.7.5 The Symantec Distrust (2017–2018)

Between 2015 and 2017, Google's Chrome security team and the CA/Browser Forum discovered that **Symantec** (which at that time owned the Thawte, GeoTrust, VeriSign, and RapidSSL certificate brands) had mis-issued thousands of certificates — including certificates for domains whose owners had not authorized them.

The problems were systemic:

- Symantec had delegated certificate issuance to third-party partners (RAs) without adequate oversight
- Test certificates for real domains were issued to unauthorized parties
- Audit logs were incomplete or missing
- Symantec initially denied the scope of the problem, then acknowledged it in stages

Google announced a graduated distrust of all Symantec-issued certificates:

- Chrome 66 (April 2018): distrusted certificates issued before June 1, 2016
- Chrome 70 (October 2018): distrusted all remaining Symantec certificates

Mozilla Firefox and Apple Safari followed with their own distrust timelines. Symantec sold its CA business to DigiCert, which re-issued certificates for affected customers under DigiCert's infrastructure.

For PDF signatures: Symantec was a major CA in the AATL (Adobe Approved Trust List). Documents signed with Symantec-issued certificates before the distrust cutoff dates would validate correctly when signed, but might show warnings or failures in PDF viewers that updated their trust stores to reflect the browser distrust. This created a time-dependent validation problem: a PDF signed with a Symantec certificate in 2015 was ”valid” when signed, ”suspect” in 2018, and — depending on the viewer’s trust configuration — might show as ”invalid” or ”valid with warnings” today.

This is exactly the problem that PAdES-B-LTA (long-term validation with archival timestamps) was designed to solve: by embedding the full certificate chain and revocation data at the time of signing, and then protecting it with periodic archival timestamps, the signature’s validity at the time of signing can be verified even after the issuing CA is no longer trusted.

2.1.8 Exploits in the Wild

A natural question: were any of these attacks exploited before or after the Bochum disclosures?

The honest answer is: **we don’t know for certain**.

PDF signatures are used in financial contracts, government documents, legal filings, tax returns, insurance claims, and medical records. If an attacker successfully forged a signature on a financial contract, the victim might not discover it until a dispute arises — and even then, the forensic analysis might not identify the specific attack technique.

What we do know:

2.1.8.1 Indicators of Real-World Exploitation

1. **The ”1 Trillion Dollar Refund” title was not hyperbole.** The paper’s title referenced the fact that tax authorities in multiple countries accept signed PDFs as official submissions. The German tax system (ELSTER), for example, processes millions of electronically signed documents per year. If USF or ISA could forge signatures on tax submissions, the financial exposure was enormous. The Bochum team coordinated with CERT-Bund (Germany’s national CERT) before publication.
2. **Adobe’s response was unusually fast.** Adobe issued CVE-2020-9592 and CVE-2020-9596 and released patches within weeks of the responsible disclosure. For a company that typically operates on monthly security update cycles, the accelerated timeline suggests Adobe assessed the risk as immediate and severe — consistent with either active exploitation or intelligence indicating exploitation was imminent.
3. **The EU Digital Signature Service (DSS) was vulnerable.** The EU’s own reference implementation for signature validation — the tool member states use to validate eIDAS-compliant signatures — was vulnerable to ISA attacks. If the EU’s own validator could be fooled, signatures submitted to government services across 27 member states could potentially have been forged without detection.
4. **Commercial signing services had no detection capability.** Before the Bochum research, no commercial PDF signing or validation service tested for these attack classes. There were no automated tools to detect ISA, SWA, or Shadow Attack patterns in submitted PDFs. Any exploitation that occurred before 2019 would have been invisible to the existing security infrastructure.

2.1.8.2 Post-Disclosure Exploitation Risk

After the papers were published and patches released, the risk shifted:

- **Unpatched viewers remain vulnerable.** Not all users update their PDF viewers. Enterprise environments, government agencies with slow update cycles, and users in regions with limited internet access may still be running vulnerable versions of Acrobat, Foxit, or other viewers.
- **The attack techniques are public.** The Bochum team published detailed descriptions and proof-of-concept PDFs. Any attacker with basic PDF knowledge can reproduce the attacks.
- **Shadow Attacks remain partially unresolved.** While most viewers now detect the Hide and Replace variants, the fundamental problem — that PDF semantics allow content to be visually hidden — is inherent to the format. New variants of Shadow Attacks are likely still discoverable.

2.1.9 The Patch Response: What Changed

2.1.9.1 Adobe's Response

Adobe's patches for CVE-2020-9592 and CVE-2020-9596 (released in the May 2020 Acrobat security update, version 2020.006.20042) implemented:

1. **Cryptographic signature verification** — closing the USF vulnerability by ensuring the CMS signature value is always verified against the document hash
2. **Byte range coverage validation** — checking that the `/ByteRange` covers the entire file from offset 0 to the file's end (minus the `/Contents` gap), closing the SWA vulnerability
3. **Incremental update analysis** — warning users when an incremental update modifies content beyond what the signature's permission level allows, closing the ISA vulnerability
4. **Shadow content detection** — partial detection of Hidden content patterns (overlapping objects, OCGs with suspicious visibility settings)

Acrobat's signature panel now displays more granular information:

- "Signed and all signatures are valid" — no modifications detected
- "Signed but the document has been modified since signing" — incremental updates detected, with details about what changed
- "At least one signature has problems" — cryptographic or structural verification failed
- "The document has been altered or corrupted since the signature was applied" — clear indication of tampering

2.1.9.2 Foxit's Response

Foxit Reader patched its signature validation in version 10.1 (released October 2020), implementing similar checks: CMS verification, byte range validation, and incremental update analysis. Foxit was notably slower than Adobe in responding — roughly five months after Adobe's patch.

2.1.9.3 LibreOffice's Response

LibreOffice (which uses the NSS library for cryptographic operations) patched its PDF signature validation in version 7.0. The fix was more complex because LibreOffice's PDF import/export pipeline differs significantly from dedicated PDF viewers — it converts PDF to an internal format for editing, which complicates byte-level signature verification.

2.1.9.4 The Broader Industry

By mid-2021, most actively maintained PDF viewers had released patches addressing the three original attack classes (USF, ISA, SWA). Shadow Attack mitigations were slower to arrive and remain incomplete in some viewers as of 2026.

The Bochum research also influenced the standards bodies:

- **ISO TC 171** (the committee responsible for ISO 32000-2:2020) incorporated the attack findings into the errata and clarifications for the second edition of PDF 2.0
- **ETSI** updated the PAdES standard (EN 319 142-1 V1.2.1, published 2022) to include explicit requirements for byte range coverage verification and incremental update validation
- **The EU Digital Signature Service (DSS)** — the open-source reference validator maintained by the European Commission — was patched and now includes specific test cases for each attack class

2.1.10 Building a Robust Validator: Lessons from the Attacks

Every attack in this chapter exploits a specific gap between what a viewer *should* check and what it *actually* checks. Here is the complete checklist, informed by every vulnerability discussed above.

Table 2.3: PDF Signature Validation Checklist (post-Bochum)

#	Check	Defends Against
1	Parse the CMS `SignedData` structure and verify it is well-formed (correct OIDs, consistent version numbers, all required fields present)	USF Variant 2
2	Verify the `SignerInfo.signature` value cryptographically against the signer's public key and the computed digest	USF Variant 1
3	Verify the message digest in the signed attributes matches the hash of the byte range content	USF Variant 3, SWA
4	Verify `/ByteRange` starts at offset 0	SWA
5	Verify `/ByteRange` gap contains the `/Contents` hex string	SWA

#	Check	Defends Against
6	Verify `/ByteRange` covers the entire file (for the signed revision) — no unaccounted bytes before, between, or after the ranges	SWA, ISA
7	If the file extends beyond the signed byte range, parse the incremental update and determine what changed	ISA
8	Verify that any changes in the incremental update are permissible under the signature's DocMDP permission level (P=1: no changes; P=2: form fills + signatures; P=3: form fills + signatures + annotations)	ISA Variant 3
9	Verify the certificate chain from the signer's certificate to a trusted root, checking revocation (OCSP/CRL) and validity dates	Certificate forgery, CA breaches
10	If a timestamp is present, verify the TSA certificate chain independently and check that the timestamp covers the correct data	Backdated signatures
11	Check for hidden content patterns: overlapping objects, Optional Content Groups with invisible layers, unreferenced Form XObjects, form fields with discrepant default/actual values	Shadow Attacks (Hide, Replace)
12	Ensure the digest algorithm is SHA-256 or stronger — reject SHA-1	SHAttered, hash collision attacks

Checks 1–6 are non-negotiable — any validator that skips them is vulnerable to at least one of USF, ISA, or SWA. Checks 7–10 are necessary for real-world security but require more complex implementation. Checks 11–12 are defense-in-depth against attacks that remain partially unresolved.

No checklist is complete. The Bochum team found these attack classes by thinking adversarially about the gap between what the spec *requires* and what implementations *do*. There will be more attacks. The defense is not just implementing these twelve checks — it is building a culture of adversarial testing into your validation code.

2.1.11 A Note on Responsible Disclosure

The Bochum team followed responsible disclosure for both papers. They notified affected vendors months before publication and provided proof-of-concept PDFs for testing.

For the CCS 2019 paper, the disclosure timeline was approximately:

- **March–April 2019**: Initial vendor notifications
- **May–August 2019**: Back-and-forth with vendors; some requested extended timelines; some did not respond

- **November 2019**: Paper presented at CCS; public disclosure
- **May 2020**: Adobe patches released (CVE-2020-9592, CVE-2020-9596)
- **October 2020**: Foxit patches released

The six-month gap between public disclosure and Adobe's patch — and the eleven-month gap before Foxit's patch — is notable. The Bochum team publicly criticized the slow response, particularly from viewers that took more than six months to patch after detailed proof-of-concept material was shared privately.

For the NDSS 2021 paper (Shadow Attacks), the disclosure process was similar but vendors responded faster, having already been through the CCS 2019 cycle.

The research materials — including proof-of-concept PDFs, the vulnerability matrix, and detailed attack descriptions — remain available at **pdf-insecurity.org**. The Hackmanit GmbH **PDF Detector** tool (available as a web service and standalone library) can check PDFs for known attack patterns.

2.1.12 Summary

PDF signature security before 2019 was, to put it bluntly, an illusion. The cryptographic primitives were sound — RSA, ECDSA, SHA-256, CMS are all well-designed and well-analyzed. The failure was entirely in how PDF viewers *used* those primitives. They verified certificates meticulously and signatures not at all.

The Bochum research (CCS 2019, NDSS 2021) exposed four attack classes:

- **USF**: The viewer doesn't check the cryptographic signature value — forge anything
- **ISA**: The viewer doesn't check for modifications after signing — append anything
- **SWA**: The viewer doesn't validate the byte range — redirect it to anything
- **Shadow Attacks**: The viewer doesn't analyze what the signed content *means* — hide anything

Every major PDF viewer was vulnerable. The patches took months to years. Some Shadow Attack variants remain partially unresolved.

Earlier events — the DigiNotar breach (2011), the Comodo RA compromise (2011), the Symantec distrust (2017–2018), and the SHAttered SHA-1 collision (2017) — had already weakened the trust infrastructure underneath PDF signatures. The Bochum attacks showed that even if you trusted the infrastructure, the validators themselves couldn't be trusted.

The lesson for implementers is clear: **verify everything, trust nothing, and test adversarially**. The validation checklist in this chapter is the minimum. The next attack class is already being researched.